

Xolvon Backend — Handover Documentation

Official handover entry point for the Xolvon backend (NestJS 12, strict ESM, Node.js 22+). This folder is the canonical, code-verified reference. The root `README.md` and `ARCHITECTURE.md` predate some hardening work; where they disagree with this folder, the documents here (and the code) win.

Document index

Document	Purpose
<code>README.md</code> (this file)	From-zero setup, environment variables, commands, migrations, PDF build
<code>architecture.md</code>	Module map, data layer (SQLite/D1), storage port, auth model, full data model
<code>security.md</code>	Security headers, input sanitization, consolidated controls, audit results, limitations
<code>deployment-runbook.md</code>	Staging → production deployment, migration apply/rollback, admin bootstrap, monitoring status
<code>api-contract.md</code>	Canonical endpoint contract (auth/role per route)
<code>decision-log.md</code>	Locked decisions (DL-nnn), conflicts, open items
<code>production-operations.md</code>	Environment separation, admin bootstrap, rollback, observability boundary
<code>qa-results.md</code>	Live-deployment verification status (currently BLOCKED — recorded honestly)

1. Prerequisites

- **Node.js** v22.0.0+ (NestJS 12 runs native ESM)
- **npm** v10+
- No Cloudflare account, database, or bucket is needed for local development.

2. From-zero local setup

2.1 Clone and install

```
git clone <repository-url>
cd Project-SaaS-Xolvon
npm install
```

`.npmrc` sets `legacy-peer-deps=true` (required by the `@nestjs/throttler` peer range, see DL-016); a clean `npm install` on a fresh clone must exit 0.

2.2 Create `.env`

```
cp .env.example .env
```

`.env` is gitignored — never commit it. The local defaults in `.env.example` run fully offline: `APP_ENV=local`, `DB_DRIVER=sqlite`, `STORAGE_DRIVER=local-test`. You must supply only two values locally (names below; put real values in `.env`, never in docs or Git):

- `JWT_SECRET` — any high-entropy string of at least 32 characters (e.g. generate one with `openssl rand -hex 32`).
- `ADMIN_BOOTSTRAP_EMAIL` / `ADMIN_BOOTSTRAP_PASSWORD` — only needed when you run `npm run seed:admin` (section 5); not read by the HTTP server.

All other blank variables (`CLOUDFLARE_*`, `R2_*`) are validated only when the matching driver is selected (`DB_DRIVER=d1` / `STORAGE_DRIVER=r2`) — see `src/config/env.validation.ts`. The validator fails fast at bootstrap and never echoes values.

2.3 Build

```
npm run build
```

2.4 Apply database migrations (local SQLite)

> **Important:** the HTTP server does **not** auto-apply migrations at startup. `src/main.ts` never runs them; `local.db` starts empty. You must > apply migrations once before the first run.

```
# Applies all pending files in src/database/migrations/ to ./local.db
npx ts-node src/database/migrate.ts
```

(`npm run seed:admin` also applies pending migrations first, so seeding implicitly migrates.)

2.5 Run locally

```
npm run start:dev # watch mode
# or
npm run start:prod # node dist/main (after npm run build)
```

The API listens on `http://localhost:PORT/api` (default `PORT=3000`). Smoke

`test` is the health route is `GET /api/` (it returns `Hello World!` and is exempt from all throttling groups):

```
curl -i http://localhost:3000/api
curl -s http://localhost:3000/api/courses # public catalog, paginated
```

3. Environment variable reference

Names and purposes only — ****no secret values belong in this repo, in Git, in logs, or in any document.**** The three templates are `.env.example` (local, 17 names), `.env.staging.example` and `.env.production.example` (15 names each); `CORS_ALLOWED_ORIGINS` is present but blank in all three. One further name is read at runtime but is not in the example files (see the row marked ***runtime-optional***).

Variable	Purpose	Required	
APP_ENV	Runtime mode: <code>local \</code>	<code>staging \</code>	<code>production</code> . <code>production</code> enables HSTS in security headers. Optional, defaults <code>local</code>
PORT	HTTP listen port (integer 1-65535).	Optional, defaults <code>3000</code>	
DB_DRIVER	Persistence driver: <code>sqlite</code> (better- <code>sqlite3</code> on <code>local.db</code>)\	<code>d1</code> (Cloudflare D1 REST adapter).	Optional, defaults <code>sqlite</code>
CLOUDFLARE_ACCOUNT_ID	Cloudflare account id for the D1 REST endpoint.	Required when <code>DB_DRIVER=d1</code>	
CLOUDFLARE_D1_DATABASE_ID	D1 database id the REST adapter queries.	Required when <code>DB_DRIVER=d1</code>	
CLOUDFLARE_API_TOKEN	Bearer token used per-query against the D1 REST API (never stored on the service instance).	Required when <code>DB_DRIVER=d1</code>	
STORAGE_DRIVER	Object storage driver: <code>local-test</code> (in-process stub, <code>http://local-storage.test</code> URLs)\	<code>r2</code> (Cloudflare R2 via S3 presigning).	Optional, defaults <code>local-test</code>
R2_ENDPOINT	S3-compatible R2 endpoint (must be absolute <code>https:</code> URL). Its origin also feeds CSP source lists.	Required when <code>STORAGE_DRIVER=r2</code>	
R2_BUCKET	R2 bucket name.	Required when <code>STORAGE_DRIVER=r2</code>	
R2_ACCESS_KEY_ID	R2 access key id.	Required when <code>STORAGE_DRIVER=r2</code>	
R2_SECRET_ACCESS_KEY	R2 secret access key.	Required when <code>STORAGE_DRIVER=r2</code>	
JWT_SECRET	HS secret for signing/verifying access tokens (<code>AuthGuard</code>).	Always required (min 32 chars)	
FRONTEND_URL	Primary allowed browser origin; CORS and request-integrity fallback when <code>CORS_ALLOWED_ORIGINS</code> is unset.	Always required (valid <code>http(s)</code> URL)	
CORS_ALLOWED_ORIGINS	Comma-separated explicit whitelist of allowed origins (credentials mode; wildcards rejected). Also the request-integrity guard's allowed-origin set. Falls back to <code>FRONTEND_URL</code> , then <code>http://localhost:3001</code> .	Optional (blank in all three example files; set real origins per environment)	
CSP_CONNECT_SRC	Comma/space-separated origins added to CSP <code>connect-src / style-src / img-src / font-src</code> . Malformed entries are dropped. Defaults to <code>'self'</code> .	Runtime-optional (not in the example files)	
TRUST_PROXY_HOPS	Express <code>trust proxy</code> hop count for client-IP resolution behind the edge proxy. Unset/blank → <code>false</code> (fail closed: <code>X-Forwarded-For</code> cannot mint fresh throttle buckets); non-numeric → bootstrap aborts. Staging/production templates set <code>1</code> .	Optional (validated at bootstrap, not by <code>env.validation.ts</code>)	
ADMIN_BOOTSTRAP_EMAIL	Email of the first admin account, consumed only by <code>npm run seed:admin</code> .	Required for <code>seed:admin</code>	
ADMIN_BOOTSTRAP_PASSWORD	Password for the first admin account, consumed only by <code>npm run seed:admin</code> .	Required for <code>seed:admin</code>	

Cross-field validation lives in `src/config/env.validation.ts` and keys off

`DB_DRIVER / STORAGE_DRIVER` — not off `APP_ENV`.

4. Commands

Command	What it does
<code>npm run test:esm</code>	Unit/behavior suite (Jest with <code>experimental-vm-modules</code> , via <code>cross-env</code>). Current baseline on this branch: 44 suites / 411 tests.
<code>npm run test:e2e</code>	End-to-end suite (<code>test/jest-e2e.json</code> harness with overridden providers). Baseline: 107 tests. Runs fully against in-memory/local SQLite — zero cloud credentials.
<code>npm run build</code>	<code>next build</code> → <code>dist/</code> .
<code>npm run lint</code>	<code>oxlint src/ test/</code> .
<code>npm run format</code>	Prettier over <code>src/</code> and <code>test/</code> .
<code>npm run test:cov</code>	Coverage report.
<code>npm run seed:admin</code>	Controlled first-admin bootstrap (section 5).
<code>npm run docs:pdf</code>	Regenerate committed PDFs (section 6).

Plain `npm test` (`jest` without the ESM flag) is **not** usable with this

ESM-only codebase — always use `test:esm` / `test:e2e` (DL-008).

5. Adding and running a migration

Migrations are plain SQL files in `src/database/migrations/`, applied by `src/database/migrate.ts` in **filename sort order**, tracked in the `_migrations` table (filename + SHA-256 content hash). Rules:

1. **Add** a new file `NNNN_short_description.sql` continuing the numeric prefix (next free number after `0007_...`). Name only — content of applied files is immutable.
2. **Never edit an applied migration**. The runner compares the recorded hash and throws on drift (`"changed after it was applied"`), fail-closed. Fix

forward with a new file.

Statements are split with a string/comment/trigger-aware splitter, so plain

; -separated DDL is safe.

4. **Run locally:** `npx ts-node src/database/migrate.ts` (applies to

`./local.db` under the current working directory; prints

`applied/skipped` counts). The HTTP server itself never runs it.

5. **Run against D1 (staging/production):**

`npx wrangler d1 migrations apply xolvon-staging --remote` — the database

name and `migrations_dir` are configured in `wrangler.jsonc`. See

`deployment-runbook.md` for the full procedure and

rollback policy (forward-only; compensating migration + deployment revert).

6. The `src/database/migrations/_reference/` folder is a reference copy and is

not applied (the runner only enumerates top-level `*.sql` files).

7. Schema changes must be preceded by a `decision-log.md` entry (RULES §84);

`SCHEMA.md` remains the schema source of truth.

6. Generating documentation PDFs

Per DL-019, official PDFs are produced with Playwright/Chromium and committed:

```
npm run docs:pdf
```

• Runs `scripts/docs-pdf.mjs`: renders the **four official handover docs**

(`README.md`, `architecture.md`, `security.md`, `deployment-runbook.md`) to

`docs/pdf/<name>.pdf` (A4, Chromium print pipeline), plus a combined

`docs/pdf/xolvon-backend-full-documentation.pdf` in that order. It does **not**

render the other `docs/*.md` (`api-contract`, `decision-log`, `qa-results`,

`production-operations`) — the deliverable set is pinned in the script.

• Requires the Chromium browser binary once per machine:

`npx playwright install chromium`.

• Output is deterministic for the same Markdown input; regenerate and

secret-scan whenever these docs change.

• `docs/Xolvon-API-Documentation.pdf` (and its generator

`scripts/generate-api-pdf.py`) were a non-conforming, out-of-band pair

(per DL-019) and were **deleted at plan T9**; they are not part of this

workflow and no longer exist in the tree. See DL-026 in

`decision-log.md`.

7. House rules for contributors

• No secret or credential values in docs, tests, logs, Postman files, PDFs, or

Git history — variable **names** only (DL-024, cleanup policy DL-025).

• No production deployment claims without real target + HTTPS domain +

verification evidence (current status: blocked, see

`qa-results.md`).

• Endpoint or auth-model changes require updating

`api-contract.md` and a `decision-log.md` entry in the

same change.

Daftar endpoint + kebutuhan auth. Dokumen ini bertambah setiap modul baru dan

disempurnakan penuh di T16 (`.omo/plans/xolvon-backend-build.md`).

- **Status dokumen:** skeleton per T4. Kolom status menandai `aktif` (sudah ada di repo) atau `planned` (didefinisikan plan, belum diimplementasikan).
- **Global prefix:** semua route dilayani di bawah `/api/*` (`src/main.ts`).
- **Auth:** *Authorization:* Bearer `<accessToken>` (JWT) — Bearer-only, tidak ada cookie session (DL-016/DL-018). Role: `user` (default) dan `admin` (`RolesGuard`). Mutation browser request (`POST/PATCH/DELETE`) additionally lolos request-integrity guard `src/common/guards/request-integrity.guard.ts` (T3): *Origin/Referer* harus ada dalam set asal yang diizinkan, *Sec-Fetch-Site:* `cross-site` ditolak; request non-browser tanpa header asal lolos (tetap butuh Bearer valid).
- **Validasi:** global `ValidationPipe` (`whitelist` , `forbidNonWhitelisted` , `transform`) — field di luar DTO ditolak.
- **Error:** global `AllExceptionsFilter` — respons aman, tanpa stack trace/internal.
- **Pagination:** kontrak terkunci di decision log DL-011 — `?page=` 1-based, `?limit=` default 20 maks 100, respons `{items, page, limit, total}` .
- **Rate limit** (per IP, jendela 60 detik, via `@nestjs/throttler` named groups — DL-012 + implementasi T6 di `src/config/throttle.config.ts`): `/auth/login` + `/auth/register` **5/min**; katalog publik list (`GET /courses` , `/projects` , `/marketplace` , `/collective` , `/home`) **30/min** (group `catalog`); `GET /search` **30/min** (group `search`); signed-URL issuance (`GET /lessons/:id/video-url` , `POST /admin/media/upload-url` , `POST /admin/media/read-url`) **10/min** (group `signed`); `POST /orders` **10/min** (group `order`); rute tak berhasil lain **100/min** (group `default`). Health `GET /api` dikecualikan dari SEMUA group (`@SkipThrottle` eksplisit per nama tracker).
- **Audit:** mutation sensitif (verify/activate/revoke/publish/cancel) menulis `admin_audit_logs` (plan T11/T15).

Endpoint aktif (sudah ada di repo)

Auth (`src/auth/auth.controller.ts`)

Method	Path	Auth	Role	Status	Deskripsi	Request	Response
POST	<code>/api/auth/register</code>	Public	-	aktif	Registrasi user baru; <code>role</code> tidak pernah diterima dari input (DL-005)	<code>RegisterDto</code>	<code>SafeUserDto</code> (201)
POST	<code>/api/auth/login</code>	Public	-	aktif	Login; mencatat IP + user agent ke sesi; rate limit menyusul (DL-012)	<code>LoginDto</code>	<code>AuthResponseDto</code> <code>{accessToken, refreshToken, user: SafeUserDto}</code> (200)
POST	<code>/api/auth/refresh</code>	Public	-	aktif	Terbit access token baru via refresh token	<code>RefreshTokenDto</code>	<code>{accessToken}</code> (200)
POST	<code>/api/auth/logout</code>	Public	-	aktif	Revoke sesi refresh token	<code>LogoutDto</code>	<code>{message}</code> (200)
GET	<code>/api/auth/me</code>	Bearer JWT	user	aktif	Profil user dari payload JWT sesi	-	<code>JwtPayload</code> (200)
GET	<code>/api/auth/admin</code>	Bearer JWT	admin	aktif	Cek akses admin	-	<code>{message, user}</code> (200)

Orders (`src/orders/orders.controller.ts`)

Method	Path	Auth	Role	Status	Deskripsi	Request	Response
POST	<code>/api/orders</code>	Bearer JWT	user	aktif	Checkout; total dihitung server-side; status awal <code>pending</code> (DL-002)	<code>CreateOrderDto</code>	<code>OrderResponseDto</code> (201)
POST	<code>/api/orders/:id/payment-proof</code>	Bearer JWT	owner order	aktif	Submit object key bukti bayar; cek kepemilikan anti-IDOR	<code>SubmitPaymentProofDto</code>	<code>{message, proofId}</code> (201)
PATCH	<code>/api/orders/:id/verify</code>	Bearer JWT	admin	aktif	Verifikasi pembayaran → <code>paid</code> ; setelah rekonsiliasi T3 hanya dari <code>pending</code> (DL-002) + audit	-	<code>OrderResponseDto</code> (200)
POST	<code>/api/orders/:id/activate</code>	Bearer JWT	admin	aktif	Aktivasi enrollment dari order <code>paid</code> ; idempoten via upsert	-	<code>OrderActivationResponseDto</code> (200)

Enrollments (`src/enrollments/enrollments.controller.ts`)

Method	Path	Auth	Role	Status	Deskripsi	Request	Response
GET	<code>/api/enrollments/me</code>	Bearer JWT	user	aktif	Daftar enrollment milik sesi (anti-IDOR, dari <code>user.sub</code>)	-	<code>EnrollmentResponseDto[]</code> (200)
PATCH	<code>/api/enrollments/:id/revoke</code>	Bearer JWT	admin	aktif	Revoke enrollment → <code>revoked</code> + audit (plan T15)	-	<code>EnrollmentResponseDto</code> (200)

App (`src/app.controller.ts`)

Method	Path	Auth	Role	Status	Deskripsi	Request	Response
GET	<code>/api</code>	Public	-	aktif	Health check / hello	-	<code>string</code> (200)

Search (`src/search/search.controller.ts`)

Method	Path	Auth	Role	Status	Deskripsi	Request	Response
GET	<code>/api/search</code>	Public	-	aktif	Pencarian lintas course, project, dan marketplace; hanya <code>published</code> :FTS; <code>?q=</code> opsional, <code>?type=course</code>	<code>project</code> <code>marketplace</code> opsional, pagination DL-011	<code>SearchQueryDto</code> <code>{items: SearchResultDto[], query, page, limit, total}</code> (200)

`SearchResultDto` hanya memuat `{type, id, title, slug, description, status}` . Search tidak pernah mengembalikan draft, private, admin-only, unpublished, atau revoked content; seluruh search term dan pagination memakai DTO validation serta bind parameters.

Home (`src/home/home.controller.ts`)

Method	Path	Auth	Role	Status	Deskripsi	Request	Response
GET	<code>/api/home</code>	Public	-	aktif	Agregasi homepage published-only (featured courses, projects, marketplace, collective) tanpa N+1; throttled group <code>catalog</code>	-	<code>HomeResponseDT0</code> <code>{courses[], projects[], marketplace[], collective[]}</code> (200)

Courses (`src/courses/courses.controller.ts`)

Method	Path	Auth	Role	Status	Deskripsi	Request	Response	
GET	/api/courses	Public	-	aktif	Katalog published-only, ?q= contains pada title (LIKE, wildcard di-escape), ?sort=latest	oldest' (default latest), pagination DL-011	-	{items: CourseCardDto[], page, limit, total, query} (200)
GET	/api/courses/:slug	Public	-	aktif	Detail published-only (draft → 404) + lessons menurut order_index ASC — ringkasan aman tanpa content / video_object_key /signed URL (SCHEMA.md §17)	-	CourseDetailDto (200) / 404	
POST	/api/courses	Bearer JWT	admin	aktif	Buat course (status awal draft, UUID server-generated) + audit create ; slug unik	CreateCourseDto	CourseCardDto (201)	
PATCH	/api/courses/:id	Bearer JWT	admin	aktif	Update parsial + audit update ; slug baru dicek unik	UpdateCourseDto	CourseCardDto (200)	
POST	/api/courses/:id/publish	Bearer JWT	admin	aktif	Transisi ketat draft → published, gate field wajib (description, price) + audit publish	-	CourseCardDto (200)	
POST	/api/courses/:id/unpublish	Bearer JWT	admin	aktif	Transisi ketat published → draft + audit unpublish	-	CourseCardDto (200)	
GET	/api/courses/:slug/lessons	Public	-	aktif	Daftar lesson published milik course published (src/lessons/course-lessons.controller.ts),urut order_index ASC: ringkasan aman tanpa content / video_object_key	-	LessonSummaryDto[] (200)	

CourseCardDto (SCHEMA.md §16): {id, title, slug, description, price, thumbnailUrl, status}. CourseDetailDto menambahkan lessons: LessonSummaryDto[] dengan LessonSummaryDto = {id, title, orderIndex, status}.

Collective (src/collective/collective.controller.ts)

Method	Path	Auth	Role	Status	Deskripsi	Request	Response
GET	/api/collective	Public	-	aktif	Member published-only. ?q= (LIKE name/role/skills), pagination DL-011,urut display_order ASC lalu created_at DESC	-	PaginatedCollectiveResponseDto {items, page, limit, total} (200)
GET	/api/collective/:slug	Public	-	aktif	Detail member + relatedProjects via project_members (published); TIDAK pernah memuat email/telepon (SCHEMA.md §57)	-	CollectiveMemberDetailDto (200) / 404
POST	/api/collective	Bearer JWT	admin	aktif	Buat member (status awal draft) + audit create	CreateCollectiveMemberDto	CollectiveMemberResponseDto (201)
PATCH	/api/collective/:id	Bearer JWT	admin	aktif	Ubah member + audit update	UpdateCollectiveMemberDto	CollectiveMemberResponseDto (200)
POST	/api/collective/:id/publish	Bearer JWT	admin	aktif	Set status published + audit publish	-	CollectiveMemberResponseDto (200)
POST	/api/collective/:id/unpublish	Bearer JWT	admin	aktif	Set status draft + audit unpublish	-	CollectiveMemberResponseDto (200)

Projects (src/projects/projects.controller.ts , src/project-media/, src/project-members/)

Method	Path	Auth	Role	Status	Deskripsi	Request	Response	
GET	/api/projects	Public	-	aktif	Portfolio published-only, ?q= contains pada title/summary, ?sort=latest	oldest' (default latest), pagination DL-011	-	{items: ProjectCardDto[], page, limit, total} (200)
GET	/api/projects/:slug	Public	-	aktif	Detail published-only (draft → 404, sama seperti slug tak dikenal); urutan cerita Problem→Solution→Tech Stack→Result→Media (sort_order ASC, video dan object key dieksklusi) → members[].role dari JOIN collective_members (SCHEMA.md §47-48)	-	ProjectDetailDto (200) / 404	
POST	/api/projects	Bearer JWT	admin	aktif	Buat project (status awal draft) + audit create ; slug unik; type string terkontrol (bukan enum final)	CreateProjectDto	ProjectResponseDto (201)	
PATCH	/api/projects/:id	Bearer JWT	admin	aktif	Update parsial + audit update ; slug baru dicek unik	UpdateProjectDto	ProjectResponseDto (200)	
POST	/api/projects/:id/publish	Bearer JWT	admin	aktif	Transisi ketat draft → published, gate field wajib (title, slug, type, summary, problem, solution) + audit publish	-	ProjectResponseDto (200)	
POST	/api/projects/:id/unpublish	Bearer JWT	admin	aktif	Transisi ketat published → draft + audit unpublish	-	ProjectResponseDto (200)	
POST	/api/projects/:id/media	Bearer JWT	admin	aktif	Attach media (objectKey, mediaType string terkontrol — enum final open decision DL-014, sortOrder) + audit create	AttachProjectMediaDto	ProjectMediaResponseDto (201)	
DELETE	/api/projects/:id/media/:mediaId	Bearer JWT	admin	aktif	Detach media ter-scope ke project (lintas project → 404) + audit delete	-	{message} (200)	
POST	/api/projects/:id/members	Bearer JWT	admin	aktif	Assign collective member dengan role eksplisit (upsert ON CONFLICT(project_id, member_id)); role string terkontrol (bukan enum final) + audit create	AssignProjectMemberDto	{projectId, memberId, role} (201)	
DELETE	/api/projects/:id/members/:memberId	Bearer JWT	admin	aktif	Remove assignment member ter-scope ke project + audit delete	-	{message} (200)	

ProjectCardDto (SCHEMA.md §46): {id, title, slug, type, summary, status}.

ProjectDetailDto (§47, urutan cerita §48): {id, title, slug, type, summary, problem, solution, techStack: string[], result, media: {id, mediaType, sortOrder}[], members: {memberId, name, role}[], status}' — media publik tanpa objectKey, video dieksklusi (butuh signed private access, T13/T14).

Admin (src/admin/admin.controller.ts)

Xcode Backend Documentation - xcode-backend-full-documentation.pdf

Method	Path	Auth	Role	Status	Deskripsi
GET	/api/admin/users	Bearer JWT	admin	aktif	Paginated user list.
GET	/api/admin/users/:id	Bearer JWT	admin	aktif	User detail.
GET	/api/admin/orders	Bearer JWT	admin	aktif	Paginated order list.
GET	/api/admin/overview	Bearer JWT	admin	aktif	User/order/enrollment summary.

Learning, media, and order operations

All routes in this table require Bearer JWT. Admin routes additionally require the `admin` role; user routes derive ownership from the JWT subject.

Method	Path	Role	Status	Deskripsi
POST	/api/courses/:courseId/lessons	admin	aktif	Create lesson.
PATCH	/api/lessons/:id	admin	aktif	Update lesson.
DELETE	/api/lessons/:id	admin	aktif	Delete lesson.
PATCH	/api/lessons/:id/reorder	admin	aktif	Reorder lesson.
POST	/api/lessons/:id/publish	admin	aktif	Publish lesson.
POST	/api/lessons/:id/unpublish	admin	aktif	Unpublish lesson.
POST	/api/lessons/:lessonId/resources	admin	aktif	Create resource.
DELETE	/api/resources/:id	admin	aktif	Delete resource.
GET	/api/lessons/:id/video-url	user	aktif	Signed lesson video URL for active enrollment.
POST	/api/progress	user	aktif	Write owned progress.
GET	/api/progress	user	aktif	Read owned progress.
PATCH	/api/enrollments/:id/revoke	admin	aktif	Revoke enrollment and audit.
POST	/api/orders/:id/cancel	admin	aktif	Cancel pending order and audit.
POST	/api/admin/media/upload-url	admin	aktif	Create validated media upload URL.
POST	/api/admin/media/confirm	admin	aktif	Confirm media upload.
POST	/api/admin/media/read-url	admin	aktif	Create private media read URL.

Historical implementation notes

The endpoint tables above are the active contract. The notes below preserve module-specific response and validation details from the implementation plan.

Courses — aktif (T5)

Endpoint sudah pindah ke tabel aktif di atas. `status` tidak pernah diterima dari input (DTO tidak memilikinya; global `ValidationPipe` `forbidNonWhitelisted` menolak field di luar DTO) — transisi status hanya via endpoint `publish/unpublish`.

Lessons & Course Resources — aktif (T6)

CRUD admin untuk lesson (`order_index`, `draft/published`) dan resource

pdf	resource	assignment; summary publik tanpa field privat.
-----	----------	--

Projects / Project Media / Project Members — aktif (T7)

Endpoint sudah pindah ke tabel aktif di atas. `type` (project), `mediaType` (media), dan `role` (member) divalidasi sebagai string terkontrol dengan batas panjang — BUKAN enum final (SCHEMA.md §45/§50/§52; open decision DL-014). Object key media privat tidak pernah muncul di respons publik.

Collective — aktif (T8)

Endpoint sudah pindah ke tabel aktif di atas. `skills` disimpan comma-separated TEXT dan `social_links` sebagai JSON array TEXT (SCHEMA.md §56); keduanya diparse di mapper menjadi `string[]` / `SocialLink[]` yang tidak pernah null.

Marketplace & Marketplace Media (T9, src/marketplace/)

Showcase murni — tidak ada logika transaksi/checkout (SCHEMA.md §60); satu-satunya permukaan komersial adalah `externalUrl` (validasi minimal https, DL-013; governance tetap OPEN — PRD §91.11).

Method	Path	Auth	Role	Status	Deskripsi	Request	Response
GET	/api/marketplace	Public	-	aktif	Listing published-only, ?q= (LIKE title/description, wildcard dis-escape), "? sort=latest"	oldest' (default latest), pagination DL-011	- {items: MarketplaceItemDto[], page, limit, total} (200)

Method	Path	Auth	Role	Status	Deskripsi	Request	Response		
GET	/api/marketplace/:slug	Public	-	aktif	Detail published-only (draft → 404); mediaurut sort_order ASC; capabilities diparse dari comma-separated TEXT	-	MarketplaceItemDetailDto (200) / 404		
POST	/api/marketplace	Bearer JWT	admin	aktif	Buat listing (status awal draft) + audit create; externalUrl wajib https valid	CreateMarketplaceItemDto	MarketplaceItemDto (201)		
PATCH	/api/marketplace/:id	Bearer JWT	admin	aktif	Update parsial + audit update; slug baru dicek unik; externalUrl divalidasi ulang	UpdateMarketplaceItemDto	MarketplaceItemDto (200)		
POST	/api/marketplace/:id/publish	Bearer JWT	admin	aktif	Transisi ketat draft → published + audit publish	-	MarketplaceItemDto (200)		
POST	/api/marketplace/:id/unpublish	Bearer JWT	admin	aktif	Transisi ketat published → draft + audit unpublish	-	MarketplaceItemDto (200)		
POST	/api/marketplace/:id/media	Bearer JWT	admin	aktif	Attach media (objectKey R2, mediaType image)	video\	deck per SCHEMA.md §63 + audit create	AttachMarketplaceMediaDto	MarketplaceMediaDto (201)
DELETE	/api/marketplace/:id/media/:mediaId	Bearer JWT	admin	aktif	Detach media ter-scope ke item (lintas item → 404) + audit delete	-	{message} (200)		

MarketplaceItemDto (SCHEMA.md §59): '[id, title, slug, description, capabilities: string[], externalUrl, status]'

Home — aktif (T10)

Agregasi published-only (featured courses, projects, marketplace, collective) tanpa N+1.

Audit — aktif internal (T11)

Belum ada endpoint — dan tidak akan punya endpoint publik. record() internal untuk modul lain; metadata tidak pernah keluar ke API publik/user.

Admin — aktif (T12)

Method	Path	Auth	Role	Deskripsi
GET	/api/admin/users	Bearer JWT	admin	Tabel users
GET	/api/admin/orders	Bearer JWT	admin	Tabel orders (kolom per PRD §45)
GET	/api/admin/overview	Bearer JWT	admin	userCount / pendingOrders / activeEnrollments

Media (R2) — aktif (T13)

Method	Path	Auth	Role	Deskripsi
POST	/api/admin/media/upload-url	Bearer JWT	admin	Presigned PUT 3600s; MIME/size/prefix divalidasi; key server-generated
POST	/api/admin/media/confirm	Bearer JWT	admin	Konfirmasi upload

Lessons video & Progress — aktif (T14)

Method	Path	Auth	Role	Deskripsi
GET	/api/lessons/:id/video-url	Bearer JWT	user aktif	Signed URL 300s; wajib enrollment aktif + lesson milik course (anti-IDOR)
POST	/api/progress	Bearer JWT	user aktif	Tulis progress; ownership dari sesi, bukan body

Orders (tambahan) — aktif (T15)

Endpoint sudah pindah ke tabel aktif di atas pada path kanonik
POST /api/orders/:id/cancel (controller src/orders/orders.controller.ts, @Controller('orders') + @Post('/:id/cancel')). Catatan rekonsiliasi: dokumen awal pernah menuliskannya sebagai POST /api/admin/orders/:id/cancel; path tersebut TIDAK pernah ada di controller dan TIDAK ada di docs/openapi.json maupun Postman — kontrak kanonik adalah POST /api/orders/:id/cancel. Semantik tetap: hanya transisi pending → cancelled yang diizinkan, dan cancel menulis audit (plan T15).

Search — aktif (T16)

Endpoint lintas entitas sudah aktif pada tabel di atas. Search bersifat public, published-only, memakai FTS5, dan mengikuti kontrak pagination DL-011.

Catatan kontrak lintas-endpoint

- **Status order:** `pending` | `paid` | `cancelled` (DL-002); **status enrollment:** `active` | `revoked` (DL-004).
- **Tidak ada endpoint delete / role-change di V1** (DL-005, PRD §44 view-only).
- Tidak ada endpoint yang menerima `role` dari input user; tidak ada registrasi admin publik.
- Respons tidak pernah memuat `password_hash` , `refresh_token` , object key privat, kredensial R2, atau stack trace.
- Semua endpoint list (aktif maupun planned) mengikuti kontrak pagination DL-011.

Architecture — Xolvon Backend

Xolvon Backend Documentation · xolvon-backend-full-documentation.pdf

Code-verified architecture reference for the NestJS 12 (strict ESM, Express platform) backend. Every claim below cites the file that implements it.

Companion documents: `api-contract.md` (endpoint contract),

`security.md` (controls), `deployment-runbook.md`

(operations), `decision-log.md` (why).

1. Request lifecycle

Bootstrap order in `src/main.ts` (all guards/pipes below are process-wide):

```
Request → Express (trust proxy: TRUST_PROXY_HOPS, src/main.ts:25–28)
→ Helmet security headers (enableSecurityHeaders, src/main.ts:35–39)
→ CORS (explicit origin whitelist + credentials, src/main.ts:43–50)
→ Global prefix /api (src/main.ts:17)
→ APP_GUARD #1 ThrottlerGuard (src/app.module.ts:65)
→ APP_GUARD #2 RequestIntegrityGuard (src/app.module.ts:66)
→ @UseGuards(AuthGuard, RolesGuard) where declared per route/controller
→ ValidationPipe { whitelist, forbidNonWhitelisted, transform } (src/main.ts:53–59)
→ Controller → Service → DatabaseService token / StoragePort token
→ AllExceptionsFilter (safe JSON error envelope, src/main.ts:62)
```

There is no middleware layer and no `NestModule` configuration anywhere — the

only `app.use()` is Helmet inside `src/security/security-headers.ts`.

`AuthGuard` is deliberately **not** global: routes that don't attach it are

public (catalog/search/home/collective/marketplace GETs); `@Public()` is

metadata consumed by `AuthGuard` only where it is attached

(`src/auth/guards/auth.guard.ts:23–30`).

2. NestJS module map

`src/app.module.ts:30–61` (import order):

Module	Directory	Responsibility		
<code>ConfigModule</code> (global)	<code>src/config/</code>	<code>.env</code> load + fail-fast <code>validateEnvironment</code> (<code>env.validation.ts</code>); CORS, CSP, trust-proxy, throttle resolvers		
<code>ThrottlerModule</code> (global, via <code>APP_GUARD</code>)	<code>src/config/throttle.config.ts</code>	5 named limit groups (§5.3)		
<code>DatabaseModule</code>	<code>src/database/</code>	<code>DatabaseService</code> DI token; driver factory <code>sqlite</code> ↔ <code>D1</code> REST adapter; migration runner		
<code>AuthModule</code>	<code>src/auth/</code>	Register/login/refresh/logout, Argon2id hashing, JWT issue/verify, hashed refresh sessions, <code>AuthGuard</code> / <code>RolesGuard</code>		
<code>EnrollmentsModule</code>	<code>src/enrollments/</code>	Entitlement checks, idempotent activation, admin revoke		
<code>OrdersModule</code>	<code>src/orders/</code>	Server-computed order totals, payment-proof submission (anti-IDOR), verify/activate/cancel transitions		
<code>CoursesModule</code>	<code>src/courses/</code>	Published-only catalog, draft-gated admin CRUD, publish gates, slug uniqueness		
<code>HomeModule</code>	<code>src/home/</code>	Published-only aggregation (featured courses/projects/marketplace/collective), no N+1		
<code>MarketplaceModule</code>	<code>src/marketplace/</code>	Showcase-only SaaS catalog; <code>externalUrl</code> minimal https validation (DL-013)		
<code>AuditModule</code>	<code>src/audit/</code>	Internal <code>record()</code> writer for <code>admin_audit_logs</code> ; no public endpoint, metadata never exits the API		
<code>CollectiveModule</code>	<code>src/collective/</code>	Talent roster (draft/published), never exposes email/phone on public reads		
<code>ProjectsModule</code> + <code>ProjectMediaModule</code> + <code>ProjectMembersModule</code>	<code>src/projects/</code> , <code>src/project-media/</code> , <code>src/project-members/</code>	Portfolio CRUD, media attach/detach (private object keys never public), member assignment (<code>type</code> / <code>mediaType</code> / <code>role</code> are controlled strings, DL-014)		
<code>LessonsModule</code>	<code>src/lessons/</code>	Lesson CRUD/reorder/publish; <code>GET /api/lessons/:id/video-url</code> mints 300s signed URLs gated by active enrollment		
<code>CourseResourcesModule</code>	<code>src/course-resources/</code>	Resource attach ('pdf'	resource\	assignment') under lessons
<code>AdminModule</code>	<code>src/admin/</code>	Read-only admin surfaces: users, orders, overview counters		
<code>MediaModule</code>	<code>src/media/</code>	<code>STORAGE_PORT</code> binding + admin upload-url/confirm/read-url endpoints		
<code>ProgressModule</code>	<code>src/progress/</code>	Lesson completion state, ownership from JWT subject		
<code>SearchModule</code>	<code>src/search/</code>	Cross-entity FTS5 search (courses/projects/marketplace), published-only		

Health endpoint: `GET /api` (`src/app.controller.ts`) — returns a static

string, exempt from every throttle group via

`@SkipThrottle(HEALTH_SKIP_THROTTLE)`.

3. Data layer — one token, two drivers

All services inject the `DatabaseService` class as DI token; the factory in

`src/database/database.module.ts:25–44` selects the implementation from

`DB_DRIVER`:

3.1 `sqlite` (local development & e2e)

`DatabaseService` (`src/database/database.service.ts`) opens `better-sqlite3`

on `./local.db` (relative to cwd) with `foreign_keys = ON`, exposing

`queryAll`, `queryOne`, `execute` — always positional `?` bind parameters

(prepared statements are mandatory per HANDBOOK_BACKEND §4.1). Zero cloud

credentials needed

3.2 d1 (staging/production)

D1RestAdapter (src/database/d1-rest.adapter.ts) wraps D1Service (src/database/d1.service.ts) behind the same three methods. D1Service POSTs {sql, params} to https://api.cloudflare.com/client/v4/accounts/<CLOUDFLARE_ACCOUNT_ID>/d1/database/<CLOUDFLARE_D1_DATABASE_ID>/query with Authorization: Bearer <CLOUDFLARE_API_TOKEN> **resolved on demand per query and never stored as an instance field** (hardening invariant, d1.service.ts:77-79). Timeout 10s; timeouts→504, network/non-OK→502 — the adapter never leaks the upstream body. onModuleInit fail-fasts on missing CLOUDFLARE_* values. (src/database/d1.module.ts exists but is imported nowhere — dead code kept for reference.) Migrations run through the same execute() contract, so the runner (src/database/migrate.ts) works on either driver; the operational path for D1 is wrangler d1 migrations apply (see runbook). Applied files are recorded in _migrations with a SHA-256 hash; hash drift throws (fail-closed, forward-only policy).

4. Storage layer — StoragePort interface-first (DL-007)

src/media/storage.port.ts defines the token STORAGE_PORT and the interface:

```
createUploadUrl(request: { key; contentType; contentLength }): Promise<string>
createReadUrl(key: string, expiresIn?: number): Promise<string>
confirmUpload(key: string): Promise<void>
```

src/media/media.module.ts:12 binds the implementation from

STORAGE_DRIVER:

Driver	Class	Behavior
local-test	src/media/local-test-storage.service.ts	Deterministic stub URLs (http://local-storage.test/...); confirmUpload records keys in memory. Used by all unit/e2e runs — tests never touch the network.
r2	src/media/r2-storage.service.ts	S3 SDK v3 against R2 (region: 'auto'): presigned PUT 3600s (signable headers: content-type/content-length) and presigned GET default 300s. Credentials only from env, never in responses.

Consumers (src/media/media.service.ts , src/lessons/lessons.service.ts)

inject the token and are unchanged when drivers are swapped. Private object keys never appear in public API responses; entitlement is checked before a read URL is minted (server owns trust).

5. Auth model — JWT Bearer + hashed refresh sessions

5.1 Tokens

- **Access:** JWT signed/verified with JWT_SECRET , TTL 15m (src/auth/auth.service.ts:132-133, 211-212). Sent as Authorization: Bearer <token>; extraction and verification in src/auth/guards/auth.guard.ts (generic 401 messages, no token echo).
- **Refresh:** cryptographically random string returned once at login; the database stores only its SHA-256 hash in sessions.refresh_token (auth.service.ts:31-33, 136-149) alongside user_id , ip_address , user_agent , expires_at . refresh looks the session up by hash and purges expired rows; logout deletes the session by hash (auth.service.ts:173-225). Plaintext refresh tokens can never be read back from a leaked database.

5.2 CSRF model (explicit non-decision to adopt cookies)

The cookie-session CSRF pattern (synchronizer token in a cookie) was **NOT adopted**. The API is Bearer-only — no authentication happens via cookies — so classic cross-site request forgery cannot carry credentials automatically. Instead, browser state-changing requests are constrained by the request-integrity guard: POST / PATCH / DELETE requests must not declare Sec-Fetch-Site: cross-site, and any Origin / Referer they carry must be in the explicit allowed-origin set (CORS_ALLOWED_ORIGINS , falling back to FRONTEND_URL). Non-mutating requests are unaffected, and headerless service-to-service clients remain compatible; authentication is still required independently on every protected route. This is the locked decision DL-018 (with DL-003 keeping the repo's JWT+refresh model over the handbook's getSession() sample); implementation src/common/guards/request-integrity.guard.ts , rationale

5.3 Rate limiting

@nestjs/throttler with five named groups, all 60s windows

(src/config/throttle.config.ts): default 100/min (undecorated routes),

search 30/min (GET /api/search), catalog 30/min (courses/projects/

marketplace/collective listings + GET /api/home), signed 10/min (lesson

video URL, media upload-url/read-url), order 10/min (POST /api/orders).

POST /api/auth/login and POST /api/auth/register are tightened inline to

5/min per IP (DL-012/DL-016). Client-IP accuracy behind an edge proxy is

controlled by TRUST_PROXY_HOPS; locally it fails closed to false so

X-Forwarded-For cannot mint fresh buckets (src/config/trust-proxy.ts).

5.4 Authorization

RolesGuard enforces @Roles('admin') on all admin surfaces; roles come

exclusively from the users row / verified JWT — never from request input

(DL-005). First-admin creation is a controlled seed command

(npm run seed:admin), not a public route.

6. Data model — 19 tables + FTS5

Schema source of truth: SCHEMA.md; applied set:

src/database/migrations/0000...0007 (19 regular tables + 3 FTS5 virtual

tables; plus the runtime bookkeeping table _migrations). Conventions

(HANDBOOK_BACKEND §3.1): TEXT UUID v4 primary keys, ISO 8601 TEXT timestamps,

INTEGER money (Rupiah) and booleans (0/1), TEXT + CHECK for enums,

prepared statements only.

6.1 Tables by domain

Domain	Tables	Notes		
Identity	users, sessions	users.role CHECK 'user'	admin; users.status defaults 'active' (no CHECK constraint); sessions.refresh_token stores SHA-256 hash (§5.1)	
Course	courses, lessons, course_resources, course_tags	courses.slug UNIQUE; lessons.order_index sequencing, is_preview 0/1, video_object_key private; resource type 'pdf'	resource\	assignment'
Transaction	orders, order_items, payment_proofs	orders.status final 'pending'	paid\	cancelled' (DL-002); server-computed orders.amount (CHECK > 0); proofs store R2 object keys + uploaded_by', anti-IDOR at submit (DL-006)
Entitlement	enrollments	UNIQUE (user_id, course_id) prevents double enrollment; status final 'active'	revoked' (DL-004); idempotent upsert on activation	
Learning	progress	Per-user lesson completion; ownership from JWT subject		
Portfolio	projects, project_media, project_tags	Narrative fields Problem→Solution→Tech→Result; project_media.object_key private, media_type controlled string (DL-014)		
Collective	collective_members, project_members	project_members(project_id, member_id) is the Portfolio→Collective M:N bridge with explicit role: display_order for listings		
Marketplace	marketplace_items, marketplace_media	Showcase only — no transactions (SCHEMA.md §60); external_url https-minimal (DL-013)		
Security	admin_audit_logs	Append-only trail for admin state mutations (verify/activate/cancel/revoke/publish/create/update/delete); never exposed publicly		
Search	course_fts, project_fts, marketplace_fts	FTS5 virtual tables kept in sync by 9 insert/delete/update triggers (0007_fts.sql); power GET /api/search		

6.2 Relationships

users 1-N sessions	(user_id FK)
users 1-N orders	(user_id FK)
users 1-N enrollments	N-1 courses (both FKs; UNIQUE pair)
users 1-N progress	(user_id FK; lesson-scoped rows)
courses 1-N lessons	(course_id FK, ON DELETE CASCADE)
courses 1-N course_resources	(via lesson/course, course_resources FK)
courses N-M course_tags	
orders 1-N order_items	N-1 courses (order_id, course_id FKs)
orders 1-N payment_proofs	(order_id FK; object keys only)
projects 1-N project_media	(project_id FK)
projects N-M collective_members	(via project_members: composite PK (project_id-projects FK CASCADE, member_id – lookup enforced in code)
projects N-M project_tags	
marketplace_items 1-N marketplace_media	
users 1-N admin_audit_logs	(actor_user_id FK)

Critical invariants (HANDBOOK §3.3, DL-002/DL-004): entitlement is

enrollments.status='active' per (user, course); expires_at columns are

enforced in queries; no delete/role-change endpoints exist in V1, so

soft-state transitions (revoke/cancel/unpublish) are the only mutations, and

each writes an audit row.

7. Framework notes

Xolvon Backend Documentation - xolvon-backend-full-documentation.pdf

- **ESM-only:** NestJS 12 with `"type": "module"`; hence

`NODE_OPTIONS=--experimental-vm-modules` in test scripts (DL-008) and

`.js`-extension imports in source.

- **Deviation from HANDBOOK_BACKEND §8** (Langkah 6/8): the handbook's

`vinext /Workers` binding path targets the frontend/Workers deployment. The

backend is Node/Express and reaches D1 through the REST adapter behind the

`DatabaseService` token — a documented deviation, conflict K-06 in

`decision-log.md`.

- **Error surface:** `AllExceptionsFilter` returns

`{statusCode, message, error, timestamp, path}` with a generic 500 message —

no stack traces, upstream bodies, or secrets.

Decision Log — Backend xolvon.com

Xolvon Backend Documentation - xolvon-backend-full-documentation.pdf

Format entri mengikuti PRD.md §92 (Open Decision Protocol) dan aturan RULES.md §84: setiap keputusan memiliki **Owner, Options, Decision, Date, Impact** — tidak ada keputusan yang diselesaikan diam-diam.

- Tanggal dokumen dibuat: 2026-09-12 (plan T4, .omo/plans/xolvon-backend-build.md).
- Entri DL-001–DL-010 adalah keputusan owner yang terkunci (draft .omo/drafts/xolvon-backend-build.md bagian "Keputusan owner (LOCKED oleh user)").
- Entri DL-011–DL-012 adalah default yang diadopsi backend dan menunggu tanda tangan owner.
- Konflik antar-dokumen dicatat di bagian [Konflik dokumen](#).
- Item yang masih terbuka diindeks di bagian [Keputusan masih terbuka](#) tanpa entri final.

Keputusan terkunci owner (LOCKED)

DL-001 — Lapisan database

Problem:
Repo memakai DIService.query() langsung (D1 REST) sehingga pengembangan lokal butuh kredensial Cloudflare; handbook menetapkan DatabaseService + better-sqlite3 untuk lokal dan jalur migrasi ke D1 untuk production.

Existing Requirement:
HANDBOOK_BACKEND.md §2:27–63 dan §8:484–518; draft keputusan owner #1.

Options:
– Tetap memakai DIService langsung di semua environment.
– DatabaseService better-sqlite3 (local.db) untuk lokal + adapter D1 di balik kontrak yang sama.

Owner:
Founder/BE Lead

Decision:
Ikuti handbook – DatabaseService berbasis better-sqlite3 (local.db) untuk development lokal; D1 REST dipertahankan hanya sebagai adapter di balik token DatabaseService saat DB_DRIVER=d1. Diimplementasikan di T1/T3.

Date:
2026-09-12

Impact:
Semua modul meng-inject token DatabaseService (bukan DIService langsung); bootstrap lokal sukses tanpa kredensial Cloudflare; src/database/d1.service.ts tidak diubah sehingga invarian hardening (commit 0c83956) tetap terjaga.

DL-002 — Status order final

Problem:
Repo memiliki status keempat awaiting_verification, sementara handbook §3.4 FINAL dan SCHEMA.md §33 menetapkan hanya tiga status.

Existing Requirement:
HANDBOOK_BACKEND.md §3.4:112–120; SCHEMA.md §33; draft keputusan owner #2.

Options:
– Pertahankan awaiting_verification sebagai status terpisah.
– Collapse ke 3 status handbook (pending | paid | cancelled).

Owner:
Founder/BE Lead

Decision:
Status order FINAL: pending | paid | cancelled. awaiting_verification dihapus; submit payment proof tetap diizinkan dan mempertahankan status pending. Rekonsiliasi service, interface, migrasi, tes, dan tabel admin dikerjakan di T3.

Date:
2026-09-12

Impact:
verifyOrder hanya menerima order pending lalu menyetel paid; tes lama yang memakai awaiting_verification diperbarui eksplisit; SCHEMA.md §33 tidak berubah karena sudah final.

DL-003 — Model sesi

Problem:
Handbook §5.1/§5.5 memakai model session-token getSession(); repo memakai JWT access + refresh token berbasis tabel sessions. Perlu satu model yang dikunci.

Existing Requirement:
HANDBOOK_BACKEND.md §5.1:160–233, §5.5; draft keputusan owner #3.

Options:
– Session-token model handbook (getSession()).
– Cookie httpOnly.
– Pertahankan JWT + refresh token milik repo.

Owner:
Founder/BE Lead

Decision:
Pertahankan model JWT + refresh token milik repo. Deviasi dari handbook getSession() didokumentasikan lewat entri ini.

Date:
2026-09-12

Impact:
AuthGuard tetap membaca Authorization: Bearer; kolom sessions.refresh_token dan sessions.expires_at wajib ada di skema (DL-004); hardening expiry/refresh eksplisit dan pesan generik dikerjakan di T17.

DL-004 — Adopsi Schema V2

Xolvon Backend Documentation - xolvon-backend-full-documentation.pdf

Problem:

Kode repo meng-query kolom yang tidak ada di SCHEMA.md maupun migrasi repo (users.status/email_verified/phone_verified, sessions.refresh_token/expires_at, courses.price); handbook §3 menambah tabel dan kolom V2 yang belum diadopsi.

Existing Requirement:

HANDBOOK_BACKEND.md §3:67–154; SCHEMA.md §28, §125–128; draft keputusan owner #4.

Options:

- Kembalikan kode ke skema lama.
- Adopsi Schema V2 penuh + sinkronisasi SCHEMA.md.

Owner:

Founder/BE Lead

Decision:

Adopsi Schema V2: tabel course_tags, project_tags, dan FTS5 (course_fts, project_fts, marketplace_fts); kolom sessions.refresh_token/expires_at/ip_address/user_agent, users.status/email_verified/phone_verified, courses.price, collective_members.display_order. Status enrollment FINAL active|revoked – expired dihapus, kolom expires_at dipertahankan dan ditegakkan di query. SCHEMA.md disinkronkan melalui proses perubahan skema eksplisit (T2).

Date:

2026-09-12

Impact:

Migrasi V2 19 tabel + index + FTS5 idempoten; SCHEMA.md menjadi sumber kebenaran tunggal; entity/field/enum baru di luar kontrak wajib memperbarui SCHEMA.md + entri decision log sebelum implementasi.

DL-005 — Admin bootstrap

Problem:

PRD §91.8 – mekanisme membuat admin pertama belum final; route registrasi admin publik dilarang.

Existing Requirement:

PRD §91.8, §44; HANDBOOK_BACKEND.md §7; ARCHITECTURE.md §165; draft keputusan owner #5.

Options:

- Route registrasi admin publik.
- Seed script server-side terkontrol.

Owner:

Founder/BE Lead

Decision:

Bootstrap admin via seed script server-side (dijalankan terkontrol di T19). Tidak ada route publik yang membuat admin; role tidak pernah diterima dari input user.

Date:

2026-09-12

Impact:

Delete dan role-change tidak memiliki endpoint di V1 (PRD §44 view-only); keadaan ini dicatat resmi di sini, bukan diselesaikan diam-diam. Endpoint admin (T12) murni read + aksi transisi status.

DL-006 — Ratifikasi payment_proofs

Problem:

PRD §91.6 menyatakan penyimpanan payment proof belum diputuskan, tetapi repo sudah mengimplementasikan tabel payment_proofs + alur submit proof. Konflik implementasi vs dokumen.

Existing Requirement:

PRD §91.6; SCHEMA.md §1023–1033 (open decision); draft keputusan owner #6.

Options:

- Hapus tabel dan alur proof.
- Ratifikasi implementasi sebagai keputusan resmi.

Owner:

Founder/BE Lead

Decision:

Tabel payment_proofs dan alur POST /orders/:id/payment-proof diratifikasi sebagai bagian kontrak V1.

Date:

2026-09-12

Impact:

PRD §91.6 terjawab; yang disimpan adalah object key (bukan berkas); antrian verifikasi admin memakai status order pending (DL-002).

DL-007 — R2 StorageService interface-first

Problem:

Modul media/R2 belum ada dan kredensial R2 production belum tentu tersedia saat pembangunan; implementasi tidak boleh menunggu atau menebak.

Existing Requirement:

HANDBOOK_BACKEND.md §6:393–414, §8:521–559; ARCHITECTURE.md §45–48; draft keputusan owner #7.

Options:

- Tunggu kredensial sebelum menulis kode media.
- Bangun StorageService ke interface, verifikasi menyusul.

Owner:

Founder/BE Lead

	Decision: Bangun <code>StorageService</code> interface-first sebagai provider yang dapat ditukar; Desain <code>PUT</code> <code>3600s</code>; <code>private</code> <code>header</code> <code>300s</code>; object key digenerate server, prefix sesuai <code>ARCHITECTURE.md §48</code>. Verifikasi terhadap <code>R2</code> nyata menyusul saat kredensial tersedia (<code>T13/T19</code>). Date: 2026-09-12 Impact: Konsumen (media, lesson video, proof) tidak berubah saat provider ditukar; kredensial tidak pernah masuk kode, tes, atau respons client.
--	--

DL-008 — Test runner

	Problem: <code>NestJS 12</code> memakai modul <code>ESM</code> murni sehingga runner test default tidak aktif tanpa konfigurasi khusus; perlu keputusan runner yang stabil untuk semua todo. Existing Requirement: <code>README</code> bagian <code>Run tests</code>; draft keputusan owner #8. Options: - Migrasi ke runner/framework test lain. - Pertahankan <code>test:esm</code> dan <code>test:e2e</code>. Owner: Founder/BE Lead Decision: Pertahankan <code>npm run test:esm</code> (unit/behavior) dan <code>npm run test:e2e</code> (harness deterministik yang meng-override provider <code>DatabaseService</code> + <code>PasswordService</code>). Date: 2026-09-12 Impact: Seluruh todo plan memakai kedua runner tersebut; tidak menambah framework test baru.
--	---

DL-009 — Scope build

	Problem: Cakupan build perlu dikunci agar tidak terjadi scope creep fitur <code>V2</code>. Existing Requirement: Draft keputusan owner #9; <code>PRD §89-90</code>; <code>SCHEMA.md §169</code>. Options: - Partial scope (modul inti saja). - Scope penuh sampai production terverifikasi. Owner: Founder/BE Lead Decision: Scope penuh sampai deployment production terverifikasi (setara Hari 1-14 tracker BE), termasuk <code>env/secrets/monitoring/rollback</code>. Date: 2026-09-12 Impact: Fitur <code>V2</code> (payment gateway otomatis, community/chat real-time, sertifikat, review/rating, wishlist, kupon/diskon, affiliate) tetap out of scope.
--	--

DL-010 — Deliverable docs

	Problem: Keputusan teknis tersebar di plan/chat; <code>RULES.md §84</code> mewajibkan decision log; <code>SCHEMA.md §95</code> mewajibkan kontrak pagination dikunci sebelum implementasi. Existing Requirement: <code>RULES.md §84:2340-2366</code>; <code>SCHEMA.md §95</code>; draft keputusan owner #10. Options: - Catat keputusan hanya di plan/chat. - Deliverable docs resmi di dalam repo. Owner: Founder/BE Lead Decision: Wajib ada docs/decision-log.md (berkas ini) dan docs/api-contract.md; api-contract.md diperbarui setiap modul baru dan disempurnakan penuh di <code>T16</code>. Date: 2026-09-12 Impact: Tidak ada keputusan yang diselesaikan diam-diam; setiap [OPEN DECISION] memiliki entri Owner/Options/Decision/Date/Impact di berkas ini.
--	---

Default yang diadopsi backend

Entri berikut adalah default teknis yang diadopsi backend agar implementasi
tidak terblokir. Keduanya menunggu tanda tangan owner; perubahan nilai setelah
implementasi wajib lewat entri decision log baru dengan owner manusia.

DL-011 — Kontrak pagination

	Problem: SCHEMA.md §95: pagination behavior belum ditentukan sumber dokumen dan DO NOT ASSUME berlaku; volume data mengharuskan pagination sehingga contract wajib dikunci sebelum implementasi. Existing Requirement: SCHEMA.md §95:2287–2298; plan T4 (memblokir T5/T7/T9/T16). Options: – Offset-based: ?offset= & ?count=. – Page-based: ?page= & ?limit=. Owner: Backend (default adopted, track owner sign-off) Decision: Kontrak pagination: ?page= 1-based, ?limit= default 20 maksimum 100; respons list berbentuk {items, page, limit, total}. Berlaku untuk semua endpoint list (courses, projects, marketplace, search, admin). Date: 2026-09-12 Impact: T5/T7/T9/T16 mengikuti kontrak ini; owner dapat mengganti kontrak hanya dengan entri decision log baru sebelum T5 mulai.
--	---

DL-012 — Ambang rate limit auth

	Problem: PRD §104 mewajibkan pembatasan percobaan login; auth.controller.ts masih T000; nilai ambang belum dikunci siapa pun. Existing Requirement: PRD §104:2718–2753; HANDBOOK_BACKEND.md §5.1; plan T17. Options: – 3 percobaan per menit per IP. – 5 percobaan per menit per IP. – 10 percobaan per menit per IP. Owner: Backend (default adopted, track owner sign-off) Decision: Rate limit /auth/login dan /auth/register: 5 percobaan per menit per IP via @nestjsjs/throttler (T17). Melebihi ambang mengembalikan HTTP 429. Date: 2026-09-12 Impact: Implementasi T17 memakai nilai ini; owner dapat mengganti ambang dengan entri decision log baru sebelum T17.
--	--

DL-013 — Validasi minimal external_url marketplace (governance tetap OPEN)

	Problem: Marketplace item menampilkan CTA ke website SaaS eksternal (PRD §55), tetapi governance 'external_url' belum final – PRD §91.11 dan SCHEMA.md §61 menegaskan aturan validasi/pengelolaan URL (valid + approved + managed) masih open decision dan melarang membangun business logic tambahan berdasarkan asumsi. Implementasi T9 tetap butuh aturan minimal agar endpoint tidak menerima nilai berbahaya. Existing Requirement: PRD §91.11 (External SaaS URL Governance); SCHEMA.md §61; plan T9. Options: – Tanpa validasi (menunggu governance final). – Validasi minimal: URL absolut valid (URL parse) + https-only; http ditolak. – Governance penuh: allowlist domain / approval workflow admin. Owner: Backend (default adopted, track owner sign-off) Decision: Validasi minimal diadopsi untuk V1 di MarketplaceService (create + update): 'external_url' harus parse sebagai URL absolut valid DAN berprotokol https; http ditolak dengan 400 (CTA me-redirect visitor keluar situs, target insecure adalah celah redirection security), string non-URL ditolak dengan 400. Governance final (approval/allowlist/management workflow) TETAP OPEN – tidak diimplementasikan dan tidak digantikan asumsi. Date: 2026-09-12 Impact: Endpoint marketplace menerima hanya https URL valid sejak T9; owner dapat mengganti/memperketat aturan dengan entri decision log baru tanpa mengubah kontrak respons. Kepatuhan MarketplaceModule sebagai showcase murni (tanpa pembayaran/transaksi, SCHEMA.md §60) tetap berlaku.
--	---

DL-014 — type / mediaType / role portfolio sebagai string terkontrol (enum final tetap OPEN)

	Problem: Plan T7 membangun modul Portfolio, tetapi SCHEMA.md §45 (project.type), §50 (project_media.media_type), dan §52 (project_members.role) menegaskan enumerasi final belum diputuskan dan melarang mengarang enum sendiri (RULES.md §84:2340–2366). Implementasi tetap butuh aturan validasi minimal. Existing Requirement: SCHEMA.md §45/§50/§52; RULES.md §84; plan T7; PRD §26–30. Options: – Mengarang enum final (dilarang SCHEMA.md – DO NOT INVENT). – Menunda modul sampai enum final (memblokir T7 tanpa dasar owner). – String terkontrol: wajib string non-kosong dengan batas panjang; nilai
--	---

	bebas sampai enum final dikunci owner.
Xdvo	Owned Documentation · xolvon-backend-full-documentation.pdf Backend (default adopted, track owner sign-off) Decision: `type`, `mediaType`, dan `role` divalidasi sebagai string terkontrol (@IsString + @NotEmpty + @MaxLength: type 100, mediaType 50, role 100) di CreateProjectDto/AttachProjectMediaDto/AssignProjectMemberDto – TIDAK ada @Enum. Enumerasi final TETAP OPEN (indeks "Keputusan masih terbuka"); menguncinya nanti hanya menambah validator di DTO tanpa mengubah kontrak respons maupun query. Date: 2026-09-12 Impact: T7 selesai tanpa asumsi enum; media publik tetap dieksklusi video/object key; perubahan nilai setelah enum final dikunci owner wajib lewat entri decision log baru.

DL-015 — Kolom "WhatsApp / Proof Reference" tabel admin orders

	Problem: PRD §45 mendaftarkan kolom "WhatsApp / Proof Reference if applicable" untuk tabel admin orders/activation, tetapi menandainya belum final. Tabel skema tidak memiliki kolom whatsapp/proof terdedikasi, dan menambahkan field baru di luar kontrak tanpa keputusan owner dilarang (SCHEMA.md §127-128). Implementasi T12 butuh keputusan eksplisit untuk kolom ini. Existing Requirement: PRD §45:1266 (kolom belum final); SCHEMA.md §127-128; DL-006 (ratifikasi payment_proofs); plan T12. Options: - Menyimpan referensi WhatsApp/proof sebagai kolom dedikasi baru (pada orders atau tabel terpisah) dan mengeksposnya di respons admin. - Tidak menyimpan kolom dedikasi; baris payment_proofs adalah referensi proof yang sah, dan kontak WhatsApp admin tercantum terpisah di halaman publik. Owner: Founder/Product Decision: TIDAK ada kolom dedikasi untuk WhatsApp/proof reference di database maupun di respons endpoint admin. Referensi proof of payment tetap merujuk pada baris payment_proofs (object key per order) yang telah diratifikasi di DL-006; kebutuhan tampilan "Proof" di FE membaca dari sana. Kontak WhatsApp admin untuk recovery/reset sudah tersedia sebagai teks statis di halaman publik (PRD §42) dan bukan data transaksi. Date: 2026-09-12 Impact: GET /admin/orders (T12) tidak mengembalikan field whatsapp/proof; tidak ada perubahan skema untuk kolom ini. Bila owner kelak menghendaki kolom dedikasi, wajib lewat entri decision log baru + perubahan skema eksplisit (SCHEMA.md §127-128).

DL-015 implementation note — T12 admin proof surface

T12 implements the locked DL-015 decision without adding a WhatsApp/proof field to the admin response. GET /api/admin/orders exposes derived activation state and safe order/user fields only; payment proof references remain owned by the existing payment_proofs flow, while WhatsApp remains static public contact copy. Any dedicated transaction reference requires a new owner decision and schema change.

DL-016 — Implementasi rate limit auth dengan @nestjs/throttler

	Problem: DL-012 mengunci ambang (5 percobaan/menit/IP untuk /auth/login dan /auth/register) tetapi belum menetapkan mekanisme implementasinya; auth.controller.ts:37 masih TODO saat T17 dimulai. Existing Requirement: DL-012; PRD §104:2718-2753; HANDBOOK_BACKEND.md §5.1:160-233; plan T17. Options: - Implementasi manual (counter in-memory + middleware custom). - @nestjs/throttler (ThrottlerModule.forRoot + APP_GUARD + @Throttle per-route). Owner: Backend (default adopted per DL-012, track owner sign-off) Decision: Mekanisme = @nestjs/throttler ^6.5.0 (versi tercatat di package.json; peer range paket masih sampai ^11 sehingga .npmrc legacy-peer-deps=true ditambahkan). Konfigurasi produksi: global default 100 req/menit/IP per route (ThrottlerModule.forRoot, name 'default', ttl 60000), login DAN register diperketat ke 5 req/menit/IP via decorator @Throttle di AuthController (route metadata meng-override module default di @nestjs/throttler). Semua route lain memakai default 100/menit – /api/health dan konten publik GET tidak dibatasi agresif. Melebihi ambang → HTTP 429 dengan pesan standar throttler ("ThrottlerException: Too Many Requests") tanpa detail internal. Pesan kegagalan login tetap generik "Invalid email or password." untuk unknown-email maupun wrong-password (anti-enumerasi, dipertahankan + diuji). Expiry/refresh eksplisit: sesi kedaluwarsa dihapus (DELETE by id) saat refresh() dan dikembalikan 401 generik – diuji unit. Date: 2026-09-12
--	--

Impact:
Ambang DL-012 kini aktif secara produksi via APP_GUARD ThrottlerGuard.
Owner dapat mengganti ambang dengan entry decision log baru; e2e memakai override module-options ketat (3/menit) untuk membuktikan pipeline guard nyata, dan menguji limit login 5/menit sesuai angka produksi.

Konflik dokumen (tercatat + resolusinya)

ID	Konflik	Resolusi		
K-01	Order status: repo memakai <code>awaiting_verification (0001_orders_enrollments.sql:16, orders.service.ts)</code> vs <code>HANDBOOK_BACKEND.md §3.4 FINAL</code> dan <code>SCHEMA.md §33</code> 'pending'	paid\	cancelled	DL-002 — repo direkonsiliasi ke 3 status (T3)
K-02	Enrollment status: migrasi repo mengizinkan <code>expired</code> vs <code>SCHEMA.md §28</code> hanya 'active'	revoked	DL-004 — <code>expired</code> dihapus; <code>expires_at</code> dipertahankan dan ditekakkan di query	
K-03	Kolom ekstra: kode meng-query <code>users.status/email_verified/phone_verified (auth.service.ts:58-61)</code> dan <code>sessions.refresh_token/expires_at/ip_address/user_agent (auth.service.ts:150-152)</code> tanpa migrasi maupun entri <code>SCHEMA.md</code>	DL-004 — diadopsi ke Schema V2, <code>SCHEMA.md</code> disinkronkan (T2)		
K-04	Model sesi: handbook <code>getSession()</code> (session-token) vs repo JWT + refresh bearer	DL-003 — repo dipertahankan; deviasi didokumentasikan		
K-05	<code>payment_proofs</code> sudah terimplementasi di repo padahal PRD §91.6 dan <code>SCHEMA.md</code> menandainya open decision	DL-006 — diratifikasi		
K-06	Deployment: handbook §8 Langkah 6/8 memakai jalur <code>vinext /Workers</code> binding; repo BE memakai Node/Express (<code>@nestjs/platform-express</code>) + adapter D1 REST	Akan dicatat resmi sebagai deviasi terdokumentasi saat production (T20); BE tetap Node/Express		

Keputusan masih terbuka

Indeks item PRD §91 dan plan yang **belum** diputuskan — entri final dengan

Owner/Options/Decision/Date/Impact akan ditambahkan saat masing-masing

diputuskan (tidak ada entri placeholder di log ini):

- PRD §91.1 — penempatan `Solve On (/solve-on)` vs Home Section/Anchor).
- PRD §91.2 — auth library final (model sesi sudah dikunci di DL-003).
- PRD §91.3 — password hashing final disesuaikan runtime (repo saat ini: argon2).
- PRD §91.4 — runtime/adapter deployment final (dikunci di T20, lihat K-06).
- PRD §91.5 — mekanisme/provider QR atau payment.
- PRD §91.7 — assignment: resource saja vs submission workflow.
- PRD §91.9 — legal copy (Terms/Privacy/Disclaimer).
- PRD §91.10 — jumlah konten awal.
- PRD §91.12 — analytics provider pihak ketiga.
- Plan T7 — enum `type` media project (string terkontrol diadopsi di DL-014; enumerasi final masih terbuka).
- Plan T9 — governance `external_url` marketplace (validasi minimal https diadopsi di DL-013; approval/allowlist/management masih terbuka).
- Plan T12 — kolom WhatsApp/proof pada tabel admin (diputuskan di DL-015; tidak ada kolom dedikasi; `payment_proofs` adalah referensinya).
- T19 — analytics/monitoring provider pihak ketiga (interface `MonitoringPort` tersedia; provider dan credential tetap OPEN sampai keputusan owner).

DL-017 — Environment, admin bootstrap, and monitoring boundary

Problem: T19 membutuhkan pemisahan local/staging/production, bootstrap admin pertama, dan structured logging/error monitoring tanpa memasukkan credential provider yang belum dipilih. Existing Requirement: ARCHITECTURE.md §§79-90/165, RULES.md §52, PRD.md §105, T19 plan. Options: - Public admin registration or ad-hoc production seed data. - Controlled server-side command using <code>ADMIN_BOOTSTRAP_EMAIL/PASSWORD</code>. Owner: Founder/BE Lead Decision: Use APP_ENV values local/staging/production with separate secret stores. The server-side <code>`npm run seed:admin`</code> command hashes through PasswordService, inserts role=admin, and is idempotent without a public route or committed credentials. Structured monitoring is represented by MonitoringPort only; provider selection and credentials remain OPEN DECISION. Rollback is deployment revert plus backup restore or a reviewed compensating migration; applied migrations are never edited. Date: 2026-09-12 Impact: Local dry-run is supported without Cloudflare credentials. Staging/production live deployment and provider selection remain T20 work and are not claimed by T19.
--

Addendum hardening decisions (T1)

DL-018 — Bearer-only request integrity

Owner: Founder/BE Lead Options: - Add a cookie-backed CSRF token flow. - Keep the API Bearer-only and enforce browser request-integrity checks using

	allowed Origin/Referer and Fetch-Metadadata policy for mutation requests.
Xdov	Documentation · xolvon-backend-full-documentation.pdf Decision: Use Bearer-only request integrity. Do not add a CSRF cookie token because the current API authentication contract uses Authorization Bearer tokens rather than cookie authentication. Browser mutation requests will be checked against the explicit request-integrity policy in T3. Date: 2026-09-12 Impact: No CSRF cookie or token secret is added. No-cookie Bearer API clients remain supported; GET requests are unaffected. Non-browser service-to-service access requires the explicit policy defined during implementation.

DL-019 — Playwright PDF artifacts

	Owner: Founder/BE Lead Options: - Keep documentation as Markdown only or generate PDFs outside the repository. - Generate Markdown-to-PDF artifacts with Playwright/Chromium and commit them. Decision: Use Playwright/Chromium for the approved Markdown-to-PDF workflow. Generated documentation PDFs are committed, including the combined document in the order README, Architecture, Security, and Deployment Runbook. Date: 2026-09-12 Impact: PDF output becomes a reviewed repository artifact and must be regenerated and secret-scanned when its source documentation changes. No credentials or private environment values may appear in the source or generated PDFs.
--	---

DL-020 — Environment CORS whitelist and origin placeholders

	Owner: Founder/BE Lead Options: - Continue using one FRONTEND_URL origin. - Parse CORS_ALLOWED_ORIGINS as an environment-specific explicit whitelist. Decision: Use CORS_ALLOWED_ORIGINS as the explicit whitelist, with a localhost fallback for local development. Staging and production origins remain OPEN placeholders until the owner supplies final domains; wildcard origins are not approved when credentials are enabled. Date: 2026-09-12 Impact: T5 must preserve local startup without a final deployment domain and must reject unknown credentialed origins. Staging and production deployment evidence remains blocked until real target origins are provided; no domain is fabricated here.
--	---

DL-021 — CSP connect and media origins

	Owner: Founder/BE Lead Options: - Allow broad CSP connect-src and media-src values. - Use explicit environment origin lists and leave unavailable deployment origins open until owner confirmation. Decision: Use explicit CSP connect-src and media-src origin lists. Final frontend, storage, and other deployment-specific origins remain OPEN placeholders until the owner confirms them. Do not enable unsafe-inline or unsafe-eval as a default. Date: 2026-09-12 Impact: T4 must document the approved local baseline and make staging/production CSP origins configurable without embedding unverified domains or secrets.
--	--

DL-022 — Monitoring provider and recipients

	Owner: Founder/BE Lead Options: - Select a monitoring vendor and alert recipients now. - Keep MonitoringPort as the boundary until provider and recipient decisions are approved. Decision: Monitoring provider and alert recipients remain OPEN. The existing MonitoringPort interface is the only approved integration boundary for this stage; no vendor SDK, endpoint, recipient address, or credential is selected. Date: 2026-09-12 Impact: Later monitoring work must record the provider, recipients, data boundary, and secret-store location in a new decision entry before production wiring.
--	--

DL-023 — Security scanner choice

Xolvon Backend Documentation · xolvon-backend-full-documentation.pdf

Owner:
Founder/BE Lead

Options:

- Adopt a named third-party or paid security scanner.
- Use repository-native scans and npm audit while scanner selection is open.

Decision:
Security scanner choice remains OPEN. T1 records no vendor commitment; current verification uses the repository-native secret-pattern review and the existing quality commands. A future scanner requires explicit owner approval and a new decision entry.

Date:
2026-09-12

Impact:
No scanner credentials, paid service, or CI integration is added. Residual scan coverage and any selected tool must be documented before the final security gate.

DL-024 — Postman production placeholders

Owner:
Founder/BE Lead

Options:

- Commit populated production credentials or target-specific values.
- Commit production environment structure with blank placeholders only.

Decision:
Postman production environments may contain names, URLs marked as placeholders, and blank secret variables only. No access token, password, API key, cookie, or other production credential may be committed.

Date:
2026-09-12

Impact:
T11 can provide importable production structure without claiming production readiness. Operators must supply values through an external secret-safe workflow.

DL-025 — Conservative cleanup policy

Owner:
Founder/BE Lead

Options:

- Remove ambiguous files and generated artifacts during hardening.
- Preserve source, migrations, evidence, and user changes; remove only proven temporary artifacts with a deletion ledger entry.

Decision:
Use conservative, reversible cleanup. Preserve source, migrations, evidence, approved PDFs, and unrelated user changes. Delete only an artifact proven to be temporary, and record its path and rationale in the cleanup ledger. Do not edit or delete secrets as a substitute for rotation or incident handling.

Date:
2026-09-12

Impact:
T12 must produce an explainable file-by-file cleanup diff and must leave required files intact. Any tracked environment secret requires separate incident handling, not silent cleanup.

DL-026 — DL-019 disposition: official PDF pipeline vs stray Python artifact

Problem:
DL-019 locked the official PDF workflow as Playwright/Chromium Markdown-PDF ('npm run docs:pdf' → 'scripts/docs-pdf.mjs', output 'docs/pdf/*.pdf', committed). Commit '9a6d1d7' ("feat: add throttle and trust proxy configurations with API documentation and Postman collection") arrived out-of-band and introduced two non-conforming artifacts: 'scripts/generate-api-pdf.py' (Python/reportlab generator reading the root Postman collection) and 'docs/Xolvon-API-Documentation.pdf' (its output, sitting loose in 'docs/').

Existing Requirement:
DL-019; plan T8/T9/T12 ('.omo/plans/xolvon-addendum-hardening-docs.md'); conservative cleanup policy DL-025 (nothing deleted without a ledger entry).

Options:

- Accept the Python-generated PDF as an additional official artifact.
- Delete the stray files immediately during T8.
- Record them as non-conforming and schedule removal/replacement at T9, where the committed Playwright PDFs (individual + combined, order README → Architecture → Security → Deployment Runbook) supersede them and the T12 deletion ledger documents the removal.

Owner:
Founder/BE Lead

Decision:
The only approved PDF generation path is Playwright: official handover docs are Markdown under 'docs/' and PDFs are generated exclusively via 'npm run docs:pdf' ('scripts/docs-pdf.mjs'). 'scripts/generate-api-pdf.py' and 'docs/Xolvon-API-Documentation.pdf' are formally declared NON-CONFORMING to DL-019 and scheduled for removal/replacement at T9 (Playwright committed PDFs; combined output covers the Postman-derived API content once T10/T11 reconcile the contract). This entry records the disposition only — per DL-025 the files are NOT deleted at T8; deletion happens in the T9/T12 pass with a deletion ledger line.

Date:
2026-09-12

Impact:
T8 documentation ships as Markdown + the sanctioned Playwright pipeline only;
Xolvon-backend-PDF generator becomes canonical. Reviewers must not treat the stray
Python/PDF pair as authoritative. T9 regenerates all committed PDFs; T12's
cleanup ledger carries the eventual deletion of both stray paths.

Disposition (executed at T9, 2026-09-12 — append-only ledger line):

Deleted as scheduled. Files removed: `scripts/generate-api-pdf.py` and

`docs/Xolvon-API-Documentation.pdf`. Reason: non-conforming to the locked

Playwright-only PDF pipeline (DL-019/DL-026); superseded by the committed

Playwright outputs `docs/pdf/README.pdf`, `docs/pdf/architecture.pdf`,

`docs/pdf/security.pdf`, `docs/pdf/deployment-runbook.pdf` and

`docs/pdf/xolvon-backend-full-documentation.pdf` (combined order README →

Architecture → Security → Deployment Runbook), all generated by

`npm run docs:pdf (scripts/docs-pdf.mjs)`. No source, test, or script

referenced the deleted paths (workspace grep: zero hits); `docs/README.md`

§6 mentions them only as scheduled-for-removal notes, which this entry

closes. The

commit 9a6d1d7 strays `Xolvon-API.postman_collection.json` and root

`README.md` remain untouched pending T11/T12 disposition.

DL-027 — Final staging/production origins and CSP origins remain OPEN

Problem:
T8 documentation must describe staging/production deployment without inventing domains. DL-020 locked the CORS whitelist mechanism and DL-021 locked the explicit CSP origin-list mechanism, but the concrete values — final staging and production frontend origins and the CSP `'connect-src'/media` origins that depend on them — have never been supplied by the owner, and `'docs/qa-results.md'` confirms no real domains exist in this workspace.

Existing Requirement:
DL-020, DL-021; plan T8 acceptance ("all current route/auth decisions are consistent"); addendum open-decision list ("Final staging and production frontend origins", "Final CSP connect-src/media origins").

Options:
– Populate example values in the docs/templates and treat them as final.
– Leave the decision open with a named owner, documenting the placeholder fallback behavior until final domains exist.

Owner:
Founder/Backend

Decision:
FINAL staging and production frontend origins, and the CSP `'CSP_CONNECT_SRC'` connect/media origin lists derived from them, REMAIN OPEN DECISIONS with owner = Founder/Backend. Until they are supplied: `'CORS_ALLOWED_ORIGINS'` and `'CSP_CONNECT_SRC'` stay unset (CORS falls back to `'FRONTEND_URL'`, CSP defaults to `'self'` + `'R2_ENDPOINT'` origin), no domain values are fabricated in docs, templates, Postman, or PDFs, and deployment evidence for those environments remains blocked. Closing this decision requires a new entry here with the exact approved origins per environment.

Date:
2026-09-12

Impact:
`'docs/README.md'`, `'docs/security.md'`, and `'docs/deployment-runbook.md'` describe these as open with the safe fallback behavior; the final gate (F3/F4) cannot claim CORS/CSP production readiness until the owner records the origins here.

DL-028 — OpenAPI contract is exported as JSON only; no Swagger UI is served

Problem:
T10 must publish the HTTP contract as `'docs/openapi.json'` without weakening the Bearer-only security posture. Serving the generated Swagger UI as an unauthenticated route would expose a full API map (and an interactive "try it" console) to anonymous visitors on every environment, including staging and production, at zero product benefit for API clients that already have the committed artifact.

Existing Requirement:
DL-016 (JWT Bearer-only auth); addendum Must-NOT-have "no paid/extra public attack surface without owner decision"; plan T10 acceptance ("decide Swagger UI exposure (local/internal only unless auth protected) in decision log").

Options:
– Serve `'SwaggerModule.setup()'` at `'/api/docs'` in all environments.
– Serve the UI only when `'APP_ENV=local'`.
– Export the document as a committed JSON artifact and never serve a UI route.

Owner:
Founder/Backend

Decision:
The application serves NO Swagger UI in ANY environment (local included). The contract ships as the committed `'docs/openapi.json'`, regenerated only by `'npm run docs:openapi' ('src/openapi/export-openapi.ts')`, which bootstraps the real app offline, forces local drivers, and fails if any live route is missing from the document. Reviewers and clients render the JSON with their own tools. Reopening UI exposure requires a new entry here plus an auth protection design.

Date:
2026-09-12

Impact:
`'package.json'` gains `'docs:openapi'`; `'src/openapi/*'` adds the document factory, export script, and contract tests; `'docs/openapi.json'` becomes a generated

DL-029 — Stray root Postman collection relocated into postman/ and removed

Problem:
Plan T11 requires the Postman artifacts at `postman/xolvon-backend.postman\_collection.json` plus `postman/environments/\*.postman\_environment.json`. Commit `9a6d1d7` (already flagged by DL-026 for its stray PDF-pair) additionally placed `Xolvon-API.postman\_collection.json` in the repo ROOT. That collection covers all 65 canonical operations (66 requests) but cannot serve the T11 acceptance criteria: zero test scripts (so `npx newman run` asserts nothing and cannot be a smoke gate), zero saved success/error examples, its second login silently OVERWRITES `accessToken` (the admin/user token chain breaks mid-folder), no `postman/environments/` files exist (staging/production placeholders per DL-024 were never created), and the root location contradicts the planned layout and the single-source-of-truth rule of DL-026/T14 reconciliation.

Existing Requirement:
DL-024 (production Postman environments = names + placeholder URLs + blank secrets only); DL-025 (conservative cleanup, every deletion logged); DL-026 (this is the Postman half of the 9a6d1d7 stray disposition); plan T11 (`.omo/plans/xolvon-addendum-hardening-docs.md`).

Options:
- Keep both collections and hope consumers pick the right one.
- Move the root file as-is into postman/ (keeps the coverage gap and broken layout).
- Rebuild the canonical collection at postman/ from docs/openapi.json, port every useful request from the stray file (its token-capture login flow, folder taxonomy, and placeholder bodies are all carried over), then delete the root copy under this ledger entry.

Owner:
Founder/Backend

Decision:
Option 3 executed at T11. `postman/xolvon-backend.postman\_collection.json` (11 folders / 75 requests) now covers ALL 65 openapi operations (checker-verified against docs/openapi.json) with class-validator-legal placeholder bodies, per-request Newman test scripts, saved success + 401/403/404/409/429 examples whose error envelopes match the real guard/service throw strings, Bearer token capture into collection variables (cookie jar explicitly unused – the API is Bearer-only), and a self-contained `10. Newman Smoke` folder. Environments ship under `postman/environments/{local,staging,production}.postman\_environment.json`; staging/production contain placeholder URLs and blank secret variables per DL-024, and final staging/production origins remain OPEN per DL-027. `npm run test:newman` is the documented local smoke path. The root `Xolvon-API.postman\_collection.json` is DELETED in the same commit as the replacement (this entry is its ledger line). The stale root README § "Postman Collection Integration" link is left for the T14 docs-reconciliation pass rather than expanded into this test commit.

Date:
2026-09-12

Impact:
Single canonical Postman artifact; the stray root file no longer misleads consumers; T14 reconciles README prose. No environment secret is committed (secret scan recorded in .omo notepad evidence t11). Deletion is reversible: the old file remains recoverable from `git show 9a6d1d7:Xolvon-API.postman\_collection.json`.

Cleanup ledger (T12)

Executed 2026-09-12 under the DL-025 conservative cleanup policy. Audit covered

`git status`, `git ls-files`, `git ls-files -o --exclude-standard`, and a

root/subfolder scan for `*.tmp`, `*.bak`, `*.log`, `Thumbs.db`, `.DS_Store`

(none tracked, none present). Tracked total before and after: 266 files — no

tracked file was deleted by this task; every deletion below is an untracked,

gitignored working-copy remnant of a scratch file that was previously committed

and already purged from tracking by commit `e91dc97` ("chore: cleanup gitignore,

purge scratch artifacts"). Each deleted file's full content remains recoverable

from history via `git show e91dc97^:<path>`.

Deleted (proven stale scratch, zero tracked references — verified by `git grep`)

Path	Reason	Recovery
t15-verification.md	Stale T15 verification scratch at repo root; no reference in any tracked doc/script/test.	<code>git show e91dc97^:t15-verification.md</code>
t3-happy.txt	Stale T3 evidence scratch at repo root; only cross-referenced by the untracked root <code>DoneClaim</code> scratch file itself, not by tracked material.	<code>git show e91dc97^:t3-happy.txt</code>
t3-failure.txt	Same as above.	<code>git show e91dc97^:t3-failure.txt</code>
learning-t3.md	Stale T3 learning scratch at repo root; only referenced by the untracked <code>DoneClaim</code> scratch, not by tracked material.	<code>git show e91dc97^:learning-t3.md</code>

Kept — needs owner decision (referenced by tracked `docs/qa-results.md`)

Path	Why kept
DoneClaim	Untracked scratch, but <code>docs/qa-results.md</code> §T19 cites it by name as the historical record that production credentials were never exercised. Deleting would strand a live documentation reference. Owner may delete once T14 reconciles the qa-results prose.
evidence-t19-happy.txt	Same: cited by name in <code>docs/qa-results.md:34-35</code> .
evidence-t19-failure.txt	Same: cited by name in <code>docs/qa-results.md:34-35</code> .
t20-happy.txt	Cited by name in <code>docs/qa-results.md</code> (BLOCKED-gate evidence for T20).

Path	Why kept
Xolvon Backends Documentation - xolvon-backends-full-documentation.pdf 20-failure.txt	backends-full-documentation.pdf cited by name in docs/qa-results.md (BLOCKED-gate evidence for T20).

Disposition notes (NOT deletions; guarded per T12 scope)

- No tracked file under `src/`, `migrations/`, `test/`, or this `docs/decision-log.md` was removed or altered beyond this ledger append.
- The out-of-band root `README.md` rewrite (commit `65ecc4d` era / post-T work)

and its stale `Xolvon-API.postman_collection.json` link are left untouched — owned by the T14 docs-reconciliation pass (already anticipated by DL-029).

- `.omo/` and `docs/pdf/` were not touched (committed artifacts by owner decision, DL-019/DL-026).
- No git history was rewritten; nothing was reset, rebased, or reverted.

Environment / secret hygiene findings

- `git ls-files | grep -E '(^/)\.env$'` → empty: no real `.env` is tracked.
- `git log --all --oneline -- .env '**/.env'` → empty: no real `.env` was ever

tracked in history. No security-incident/rotation action required.

- `.gitignore` verified: ignores `.env`, `.env.*` (with `!.env.example / !.env.*.example` exceptions), `local.db / local.db-journal / local.db-wal / local.db-shm / *.db*`, `DoneClaim`, `evidence-*.txt`, `learning-*.md`, `t[0-9]*-*.txt`, `t[0-9]*-*.md`, `/omo`, `.codegraph`, `dist`, `buildinfo`, OS junk (`.DS_Store`, `Thumbs.db`), and `*.tmp / tmp/` patterns.
- `.env.example`, `.env.local.example`, `.env.staging.example`, `.env.production.example` all remain present and unmodified.
- Variable-name reconciliation vs `src/config/env.validation.ts`: MATCH — every

validated variable (`JWT_SECRET`, `FRONTEND_URL`, `PORT`, `APP_ENV`, `DB_DRIVER`, `STORAGE_DRIVER`, `CLOUDFLARE_ACCOUNT_ID`, `CLOUDFLARE_D1_DATABASE_ID`, `CLOUDFLARE_API_TOKEN`, `R2_ENDPOINT`, `R2_BUCKET`, `R2_ACCESS_KEY_ID`, `R2_SECRET_ACCESS_KEY`) appears in the example files. No silent source edits were made.

- FLAG (informational, no action by T12): `CORS_ALLOWED_ORIGINS` is consumed by `src/config/cors.ts` (falls back to `FRONTEND_URL`, then the local dev origin, so bootstrapping is unaffected) but is documented in none of the four example files. Owner/docs task should add it to `.env.staging.example` and `.env.production.example` alongside the DL-027 final-origin decision.

Dependency vulnerability management (T13)

DL-030 — Dependabot + npm audit as the scanning approach; 4 residual HIGHs are owner decisions

Problem:

T2/T13 `npm audit --json` (2026-09-12, evidence `.omo/notepads/xolvon-addendum-hardening-docs/evidence/t13-audit-before.json`) reports 0 critical, 4 high, 1 moderate, 2 low. `npm audit fix` (non-breaking, no `--force`) is a verified no-op: it exits 1 with the identical 7 findings and produces an empty git diff on `package.json/package-lock.json` — every fix is either unavailable or semver-major/breaking, so no safe automated remediation exists today. Per the addendum rule "no paid scanner without owner decision" (DL-023), the recurring-scan mechanism must be chosen and the unfixable HIGHs must be recorded, not silently left open.

Existing Requirement:

DL-023 (scanner choice was OPEN, paid vendor requires owner approval); plan T13 (`.omo/plans/xolvon-addendum-hardening-docs.md`); addendum §1.5.

Options:

(a) Paid scanner vendor — rejected, requires owner approval per DL-023.
(b) Dependabot (free, repository-native, GitHub-hosted) — selected.
(c) Manual periodic `npm audit` only — no continuous coverage.

Decision:

1. Scanning approach: GitHub Dependabot via `.github/dependabot.yml` — weekly npm version updates (mon 07:00 Asia/Jakarta, minor+patch grouped, open-pull-requests-limit: 5, commit-message prefix `chore` to match repo style) plus the github-actions ecosystem. npm audit remains the local gate (`npm audit --json` in final verification). No paid scanner/vendor was added. Enabling Dependabot security updates in repository settings is an owner/repo admin action (GitHub UI), noted here as the activation dependency.

2. Residual HIGH advisories — owner decisions, deliberately NOT auto-fixed (all fixes are breaking or nonexistent; forcing them would violate the no-break-the-build rule and this repo does not touch app source for audit):

– multier <=2.2.0 [HIGH] (4 advisories incl. GHSA-wc9g-mqfw-jrwm DoS via crafted multipart field names; GHSA-qfvm-cv95-qjff fd-leak DoS; GHSA-535w-7cp7-47q4 oversized-array-index DoS; GHSA-qvfw-j98x-7q72 size-limit bypass [low-severity sub-advisory]) pulled in by @nestjsjs/platform-express@12.0.1. fixAvailable=false: the newest @nestjsjs/platform-express (12.0.1) still pins multier@2.2.0 and multier@2.3.0 (the fixed line) is not consumed by any platform-express release. Why not auto-fixed: would require either waiting for an upstream NestJS patch or adding a package.json "overrides" entry for multier@2.3.0 — an unaudited manifest change outside this task's permitted remediation set. Owner options: add `overrides: { "multier": "^2.3.0" }` after validating the upload paths (admin media upload, payment-proof), or wait for @nestjsjs/platform-express to ship the bump. Mitigating facts: multier is

only reached through Nest platform-express multipart routes; core app uploads flow through presigned R2 URLs, not multipart bodies.

Xolvon Backend Documentation · xolvon-backend-full-documentation.pdf

- @nestjsjs/platform-express * [HIGH] – same finding surfaced on the direct dependency (via: multer). Same owner decision as above.
- undici <=6.27.0 [HIGH] (15 advisories incl. GHSA-f269-vfmq-vjvj WebSocket length overflow crash; GHSA-vm6-8vpv-qv8q unbounded memory; GHSA-v9p9-hfj2-hcw8 unhandled exception; GHSA-vxpw-j846-p89q fragment DoS) and tmp <=0.2.5 [HIGH] (GHSA-ph9p-34f9-6g65 path traversal; GHSA-52f5-9888-hmc6 symlink write), plus @nestjsjs/mau * [MODERATE] and the two linked LOWs (inquirer 3.0.0-8.2.6|[9.0.0-9.3.7 via external-editor; external-editor >=1.1.1 via tmp): ALL reachable only through the devDependency @nestjsjs/mau@0.2.6 (chain: @nestjsjs/mau -> ... -> undici; @nestjsjs/mau -> inquirer -> external-editor -> tmp). The only fix npm offers is @nestjsjs/mau@0.0.6 marked isSemVerMajor:true – a downgrade to a much older artifact, breaking, and 0.0.6 does not even appear in the package's published version list. Why not auto-fixed: major/breaking, explicitly out of safe scope. Owner options (recommended): verify @nestjsjs/mau is genuinely unused (grep of src/test/scripts/nest-cli.json finds ZERO references – it appears to be leftover Nest CLI tooling) and 'npm uninstall @nestjsjs/mau', which closes 1 moderate + 2 high + 2 low in one step with no runtime impact; or pin and accept, since all four dev-only packages never ship in 'dist/' and are not reachable in the production runtime (npm-start path is 'node dist/main' with no inquirer/tmp/undici imports from app code).

Date:

2026-09-12

Impact:

Continuous dependency scanning lands without any paid vendor (DL-023 closed: Dependabot selected). Gates stay green untouched by dependency churn (package.json/package-lock.json unchanged this task). The 4 HIGH + 1 MODERATE + 2 LOW residuals become explicit, dated owner decisions with concrete paths instead of audit noise; production runtime is dev-only-surface for 6 of the 7 findings, and the multer pair depends on an upstream NestJS release or a reviewed overrides entry.

Deployment Runbook — Xolvon Backend

Xolvon Backend Documentation · xolvon-backend-full-documentation.pdf

Step-by-step operating procedure for promoting this backend to staging and production, including migrations, rollback, first-admin bootstrap, and the (currently open) monitoring decision. Read `production-operations.md` for policy and `qa-results.md` for the verified state.

0. Current honest status

- **Local:** fully working — SQLite (`DB_DRIVER=sqlite`) + local-test storage (`STORAGE_DRIVER=local-test`), no cloud credentials.

- **Staging/production:** **NOT deployed and NOT verified.** The D1/R2 live path is blocked for lack of a deployment target, secret stores, wrangler access, and final HTTPS domains (recorded in `qa-results.md`). Nothing in this runbook may be marked done without real evidence; do not claim success from a local dry run.

- **Unblock requirements** (from `qa-results.md`): separate staging/production secret stores with valid D1/R2/JWT values, an authenticated deployment provider/target for the Node service, pre-migration backups, log access, and real HTTPS domains for both environments.

1. Deployment architecture (documented deviation)

The backend runs as a **Node/Express NestJS service** (`@nestjs/platform-express`, `node dist/main`). Cloudflare D1 is reached **over its REST API through the `D1RestAdapter` behind the `DatabaseService` token** (`DB_DRIVER=d1`), and R2 through the S3-compatible SDK behind `STORAGE_PORT` (`STORAGE_DRIVER=r2`). `HANDBOOK_BACKEND.md` §8 Langkah 6/8 shows swapping `DatabaseService` to a `Workers env.DB` binding and deploying via `vinext / @vinext/cloudflare` — that path belongs to the **frontend/Workers deployment**. For this backend it is a **documented deviation** (conflict K-06 in `decision-log.md`): the service is not a Workers runtime target; do not attempt to deploy `dist/main` with `vinext`.

2. Configuration per environment

Copy names only from the committed templates and populate values in the target's secret store — never in Git, docs, logs, or shell history:

Template	Fixed shape (non-secret)
<code>.env.staging.example</code>	<code>APP_ENV=staging</code> , <code>DB_DRIVER=d1</code> , <code>STORAGE_DRIVER=r2</code> , <code>TRUST_PROXY_HOPS=1</code>
<code>.env.production.example</code>	<code>APP_ENV=production</code> , <code>DB_DRIVER=d1</code> , <code>STORAGE_DRIVER=r2</code> , <code>TRUST_PROXY_HOPS=1</code>

Both templates still need real values for `CLOUDFLARE_ACCOUNT_ID`, `CLOUDFLARE_D1_DATABASE_ID`, `CLOUDFLARE_API_TOKEN`, `R2_ENDPOINT`, `R2_BUCKET`, `R2_ACCESS_KEY_ID`, `R2_SECRET_ACCESS_KEY`, `JWT_SECRET`, `FRONTEND_URL`, and optionally `PORT`. In addition, set the two runtime-optional names per environment once domains are decided (DL-020/DL-021/DL-027):

- `CORS_ALLOWED_ORIGINS` — final staging/production frontend origins (comma separated). **OPEN** — owner has not supplied final domains. Wildcards are rejected when credentials mode is on.
- `CSP_CONNECT_SRC` — frontend origins allowed in CSP fetch/source lists.

OPEN until confirmed; unset is safe (defaults to `'self'` + `R2_ENDPOINT` origin).

Validation is fail-fast at bootstrap (`src/config/env.validation.ts`): `d1` requires the three `CLOUDFLARE_*` names; `r2` requires the four `R2_*` names; `JWT_SECRET` ≥ 32 chars and a valid `FRONTEND_URL` are always required. `TRUST_PROXY_HOPS` must be a non-negative integer string or the process aborts before binding a port.

3. Provisioning D1 and R2 (once, per environment)

1. Auth wrangler on the operator machine: `npx wrangler login`.
2. D1 database — staging already exists and is the committed binding target in `wrangler.jsonc` (`database_name: "xolvon-staging"`, binding `DB`, `migrations_dir: "src/database/migrations"`). Production requires a new `npx wrangler d1 create xolvon-production` (name TBD by owner); record the resulting id **only** in the secret store as `CLOUDFLARE_D1_DATABASE_ID` —

never in documents.

3. `R2 bucket`: `npm wrangler n2-bucket create --bucket`; mint an API token scoped to read/write on that bucket; store endpoint/keys as the four `R2_*` env names.

4. Deployment target for the Node process: **not yet provisioned** — any Node-capable host/PaaS that can hold a secret store and sit behind HTTPS with a known proxy hop count. Decide and record it in `decision-log.md` before first deploy (relates to PRD §91.4, open).

4. Migration apply

- **Staging/production (D1):**

`npm wrangler d1 migrations apply xolvon-staging --remote` (repeat with the production database name for production). Take a D1 backup before the first apply of any release.

- The in-repo runner (`src/database/migrate.ts`) applies files in `src/database/migrations/` in filename order, records each with a SHA-256 hash in `_migrations`, skips applied files, and **throws on hash drift** — applied migrations are immutable. The HTTP server does not auto-migrate.
- Never edit an applied migration; add a new numbered file (see `README.md` §5).

5. Staging → production deployment procedure

Do staging first; production is the same sequence with production values.

5.1 Staging

1. Prereqs from §0 satisfied; backup of the staging D1 taken.
2. Apply pending migrations (§4) against the staging database.
3. Deploy the built artifact (`npm ci && npm run build` → ship `dist/`, or the provider's equivalent) with the staging env populated (§2).
`package.json` exposes only `deploy: "nest deploy"` as a placeholder — it targets no configured staging/production platform, so the actual deployment mechanism is the provider target from §3.4 (still unprovisioned).
4. Health check: `curl -i https://<staging-host>/api` → expect 200. Verify headers on the response: CSP present with the configured origins, `X-Content-Type-Options: nosniff`, `X-Frame-Options: DENY`, `Referrer-Policy: strict-origin-when-cross-origin`, no `X-Powered-By`;
no HSTS on staging (production-only, by design).
5. Functional smoke (clean accounts, throwaway data):
 - `POST /api/auth/register` then `login`; repeat login 6× → 6th returns 429 (auth 5/min).
 - `GET /api/courses` → 200; burst 31× → 429 (catalog 30/min).
 - Browser-mutation integrity: `POST /api/orders` with a disallowed `Origin` header → 403; without browser headers + valid Bearer → passes auth path.
 - CORS: allowed origin `OPTIONS` preflight returns `Access-Control-Allow-Origin` + credentials; unknown origin does not.
6. First admin (§6).
7. Record evidence (status codes, header dumps) without copying tokens or secret values anywhere.

5.2 Production

1. Same as staging with production secret store, plus:
2. `APP_ENV=production` → HSTS `max-age=31536000`; `includeSubDomains` must appear; confirm only after HTTPS is terminating correctly, since HSTS is sticky in browsers.
3. `CORS_ALLOWED_ORIGINS` / `CSP_CONNECT_SRC` set to the final owner-approved domains (blocked on DL-027 — OPEN).
4. Repeat the §5.1 smoke matrix against the production host on a clean account, then promote real content.
5. Any production success claim requires captured live evidence — the current recorded state is **BLOCKED** (`qa-results.md`).

6. First-admin bootstrap (controlled)

There is no public admin registration route and no role input is ever accepted

from a client (DL-005/DL-017). Seed the first admin from a controlled operator

✗ shell with the target environment's secret store attached, using the variable names only (values from the secret store; avoid shell history — e.g. read them from a file descriptor or interactive prompt):

```
ADMIN_BOOTSTRAP_EMAIL='<admin email>' \
ADMIN_BOOTSTRAP_PASSWORD='<from secret store>' \
npm run seed:admin
```

Behavior (`src/database/seed-admin.ts` → `admin-bootstrap.ts`): applies pending migrations, hashes the password with Argon2id via `PasswordService`, inserts `role='admin', status='active'`, prints only `created` or `already_exists`, is idempotent for the same admin email, and **refuses** (conflict error) to touch an existing non-admin account.

7. Rollback

Authoritative procedure: `production-operations.md`

"Rollback procedure". Short form, in order:

1. Stop promotion; record deployment id, last-applied migration filename, and incident timestamp (no secret values).

2. **Revert the deploy** to the last known-good immutable build and confirm

it boots with the target secret store (`GET /api health`).

3. **Revert the last migration** only if the failed release applied one:

restore the pre-migration database backup/snapshot taken before that apply.

The runner is forward-only and creates no down-migrations.

4. If the platform cannot restore, ship a **compensating migration** as a new numbered file that reverses the affected change. **Never edit an applied migration** — `_migrations` hash drift must fail closed.

5. Re-run the migration set against a disposable local copy first; verify

`PRAGMA foreign_key_check` and the affected flows; redeploy known-good.

6. Keep the failed release isolated until root cause + forward fix are reviewed.

8. Monitoring & alerting — OPEN DECISION

`MonitoringPort` (`src/observability/monitoring.port.ts` :

`captureError`, `recordEvent`) is **interface-only** — no provider SDK,

endpoint, recipients, or credential is wired (DL-022). Log/monitor hygiene in

the meantime (enforced by `AllExceptionsFilter` and code review): event names,

route/status context, non-sensitive identifiers only; never passwords,

tokens, hashes, signed URLs, credentials, or echoed untrusted input.

Before any production monitoring wiring, a new decision entry must record

provider, alert recipients, data boundary, and secret-store location. Until

then, treat "monitoring" as: structured stdout logs + provider platform

metrics + the \$5.1/\$5.2 smoke checks per release.

9. Post-deploy checklist (per release)

- [] Migrations applied cleanly (count matches expected new files; no drift)
- [] Health `GET /api 200` through HTTPS
- [] Header matrix correct for the env (HSTS only in production)
- [] CORS allow/deny spot check; no wildcard-with-credentials
- [] Auth 5/min + one named group 429 observed
- [] Disallowed-Origin browser mutation → 403
- [] Admin seed/verify/activate/revoke happy path on clean accounts
- [] Evidence captured with zero secret values
- [] `qa-results.md` / runbook updated with real status (or an honest BLOCKED)

Environment separation

Use the same NestJS application architecture with separate values and secret stores:

Environment	Database	Storage	Required operational checks
local	sqlite / local.db	local-test	migrations, auth, course, lesson, admin flows
staging	d1	r2	Cloudflare bindings, auth, upload, private media, integration
production	d1	r2	HTTPS/domain, secrets, analytics, monitoring, rollback

Never copy production values into `.env`, tests, screenshots, logs, documentation, or a client bundle. `R2_ACCESS_KEY_ID`, `R2_SECRET_ACCESS_KEY`, `CLOUDFLARE_API_TOKEN`, `JWT_SECRET`, and admin bootstrap password are server-only.

Controlled admin bootstrap

There is no public admin registration route. Run this command only from a controlled operator shell with the target environment's secret store attached:

```
ADMIN_BOOTSTRAP_EMAIL='admin@example.invalid' \  
ADMIN_BOOTSTRAP_PASSWORD='set-in-secret-store-not-shell-history' \  
npm run seed:admin
```

The command runs pending migrations, hashes the password through `PasswordService`, inserts `role='admin'`, and prints only `created` or `already_exists`. It is idempotent for an existing admin. It refuses to change an existing non-admin account. Do not place either variable in a committed file or command history.

Rollback procedure

1. Stop promotion and record the deployment identifier, migration filename, and incident timestamp. Do not print or copy secret values.
2. Revert the application deployment to the last known-good immutable build using the hosting provider's deployment rollback command. T19 does not claim a live provider deployment; execute this only in the configured staging/production platform.
3. Confirm the reverted build starts with the target environment's secret store and run the health check. Check logs for event names and status only.
4. If the failed release applied the latest migration, restore a database backup/snapshot taken before that migration. The repository migration runner is forward-only; it does not invent down migrations.
5. If the platform requires an explicit compensating migration, create a new numbered migration that reverses the affected schema change. Never edit an applied migration because `_migrations` hash drift must fail closed.
6. Re-run the migration runner against a disposable local copy first, then verify `PRAGMA foreign_key_check` and the affected application flow.
7. Re-deploy the last known-good build, verify auth, admin authorization, storage access, and error responses, and record evidence without credentials.
8. Keep the failed deployment isolated until the root cause and a forward fix are reviewed. Do not claim production recovery from a local dry run.

Observability boundary

Application errors use the local `MonitoringPort` interface in `src/observability/monitoring.port.ts`; no provider SDK or credential is selected in T19. The provider decision remains open. Logs and monitoring events must contain event names, route/status context, and non-sensitive identifiers only. They must not contain passwords, tokens, hashes, signed URLs, R2 credentials, or exception messages copied from untrusted input.

T20 QA Results

Xolvon Backend Documentation - xolvon-backend-full-documentation.pdf

Status

BLOCKED

T20 live deployment verification was not performed. No staging or production success is claimed, and no credential values, deployment identifiers, domains, metrics, or external service results were fabricated.

Prerequisite gate

The required deployment prerequisites are unavailable or unverifiable in this workspace:

- No separate staging secret store or populated staging target environment was found. `.env.staging.example` contains the required variable names but no usable target values.
- No separate production secret store or populated production target environment was found. `.env.production.example` contains the required variable names but no usable target values.
- A local `.env` exists and has populated entries, but its values were not read or printed and it does not establish which values belong to staging or production. It therefore cannot be treated as valid environment-specific deployment credentials.
- No process environment contains non-secret staging/production target or domain variables.
- No deployment target/provider configuration was found for the Node/Express

NestJS service. `package.json` has no staging/production deploy script;

`wrangler.jsonc` contains only a D1 binding, with no application target, environment blocks, R2 binding, or custom-domain configuration. The `wrangler` executable is unavailable.

- No real staging or production domain/HTTPS endpoint was provided or found.
- T19 output (`DoneClaim`, `evidence-t19-happy.txt`, and `evidence-t19-failure.txt`) explicitly records that production credentials and infrastructure were unavailable and that live deployment remained T20.

Because `DB_DRIVER=d1` requires the three Cloudflare values and `STORAGE_DRIVER=r2` requires the four R2 values, the application cannot be started against the required staging or production services from this workspace. A deployment target, authenticated target identity, and real domains are also required for the staging-to-production and HTTPS checks.

T20 scenarios

Scenario	Result	Evidence
t20-happy : staging then production deployment and clean-account purchase/verify/activate/access/revoke/video/upload/login/logout/session-expiry checks	BLOCKED	No verifiable environment-specific D1/R2 credentials, deployment target identity, provider executable/configuration, or staging/production HTTPS domains
t20-failure : record failed checklist items before claiming completion	BLOCKED	Same prerequisite gate; no live endpoint was available to exercise

No live success is claimed. The blocked evidence records are `t20-happy.txt` and `t20-failure.txt`; both explicitly state that no live endpoint was available and contain no secrets.

Local verification only

The following checks are local repository checks and do not substitute for T20 deployment verification:

- `npm run build`
- `npm run lint`
- `npm run test:esm`
- `npm run test:e2e`

Observed on 2026-09-12:

- `npm run build` exited 0.
- `npm run lint` exited 0.
- `npm run test:esm` passed 36 suites and 314 tests.
- `npm run test:e2e` passed 1 suite and 83 tests.
- LSP diagnostics could not run because the TypeScript LSP is not installed;

installation had previously been declined. Markdown has no configured LSP.

These results cover local code only. They do not change the BLOCKED status of the live deployment gate.

Unblock requirements

Xolvon Backend Documentation - xolvon-backend-full-documentation.pdf

Provide separate staging and production secret stores containing valid D1, R2, JWT, and frontend URL values; provide the deployment provider/target, its authenticated access and executable/configuration; provide pre-migration backup/rollback and log access; and provide real HTTPS domains for both environments. The local `.env` must not be assumed to satisfy this gate.

After those prerequisites exist, T20 must deploy staging before production, run the complete checklist against clean accounts and real services, capture the resulting `t20-happy` and `t20-failure` evidence, monitor logs, and only then record a non-blocked result.

Official security documentation for the XOLVON backend. Decisions behind the controls listed here live in `decision-log.md`; endpoint and auth contracts live in `api-contract.md`.

Security headers

All responses — including CORS preflight replies and error bodies — carry a strict header set produced by `Helmet`, wired globally in `src/main.ts` before CORS, the validation pipe, and the exception filter. The configuration lives in `src/security/security-headers.ts` and is covered by `src/security/security-headers.spec.ts`.

Header	Value	Rationale
Content-Security-Policy	<code>default-src 'none'; script-src 'self'; frame-ancestors 'none'; connect-src/style-src/img-src/font-src 'self' + configured origins</code>	Deny-by-default policy for any embedded resource. The API serves JSON, so nothing legitimate needs inline scripts or framing; <code>unsafe-inline</code> and <code>unsafe-eval</code> are never emitted (DL-021). <code>frame-ancestors 'none'</code> blocks clickjacking of every response.
Strict-Transport-Security	<code>max-age=31536000; includeSubDomains</code> — only when <code>APP_ENV=production</code>	One-year HTTPS pinning in production. Local and staging intentionally run over plain HTTP, so the header is absent there to avoid locking browsers out of dev origins.
X-Frame-Options	DENY	Legacy framing protection alongside CSP <code>frame-ancestors</code> , for older clients.
X-Content-Type-Options	<code>nosniff</code>	Stops browsers from MIME-sniffing responses into executable/script contexts.
Referrer-Policy	<code>strict-origin-when-cross-origin</code>	Cross-origin requests only receive the origin as referrer, so tokens or identifiers in URLs never leak to third parties; HTTPS → HTTP downgrades send nothing.
X-Powered-By	removed	Express' default fingerprint is disabled at the app level and stripped by <code>Helmet</code> , reducing reconnaissance surface.

CSP origin sources

The fetch/media source lists (`connect-src`, `style-src`, `img-src`, `font-src`) are built at bootstrap from environment variables, always prefixed with `'self'` as the safe default when nothing is configured:

Variable	Feeds	Notes
<code>CSP_CONNECT_SRC</code>	all four source lists	Comma- or space-separated absolute <code>http(s)</code> URLs. Each entry is normalized to its origin; malformed or non- <code>http(s)</code> values are dropped and never echoed into the header.
<code>R2_ENDPOINT</code>	all four source lists	Only the URL origin is used (e.g. <code>https://<account-hash>.r2.cloudflarestorage.com</code>); bucket names, paths, and credentials are excluded.

Approved baseline example (staging/production final origins remain OPEN per DL-021 until the owner confirms domains):

<code>CSP_CONNECT_SRC=https://app.xolvon.com,https://admin.xolvon.com</code>
--

No secrets, tokens, or credentials appear in any header value.

Verification

- Unit/config level: `src/security/security-headers.spec.ts` (runs under `npm run test:esm`) asserts the full header set on a real Nest testing app for both `production` (HSTS present) and non-production (HSTS absent), plus origin-parsing edge cases and the no- `unsafe-*` rule.
- Surface level: `curl -s -i` against the local server with and without `APP_ENV=production` (evidence in the plan notepad, `.omo/~/evidence/`).

Input sanitization

Free-text input is normalized by a bounded, deterministic policy before it can be persisted, implemented in `src/common/sanitization/` and wired per field through the existing global `ValidationPipe` (`whitelist/forbidNonWhitelisted/transform` in `src/main.ts` are unchanged).

Policy — `sanitizeText(value, { maxLength, allowHtml })`:

- Content fields intended for rendered HTML (`allowHtml: false`, the default and the only mode in use) have every tag-shaped substring (`<...>`) removed (a fixed-point sweep re-checks defensively), so payloads such as `<scr<script>ipt>` or `<b>script>` never survive. The backend never stores raw executable HTML/script content.
- Invisible control characters (NUL, ESC, and the rest of C0/DEL except `\t \n \r`) are stripped.
- Everything else — including ordinary Unicode (emoji, accented Latin, CJK), ampersands, and quotes — is preserved byte-for-byte. No trimming, case changes, or truncation: a valid request's visible content is never altered.

- Oversized values are rejected with `400`, not truncated: every sanitized field carries an explicit `@MaxLength`, and the helper's `maxLength` option

throws (never echoes the value) for programmatic callers.

`Policy.fromJSONMetadata.(parseSafeJson, @IsSafeMetadata):`

- Metadata TEXT fields that may carry structured content (project `tech_stack`)

follow "JSON-shaped means JSON-valid": a value starting with `[` or `{` must

parse as a complete JSON document or the request is rejected with `400`;

malformed payloads are never stored for read mappers to silently degrade.

Legacy comma-separated lists remain valid, matching `parseTechStack` in

`src/projects/mappers/project.mapper.ts`.

Sanitized fields (create + update DTOs): `courses.description`, `lessons.content`, `projects.summary/problem/solution/result`, `marketplace.description`, `collective.bio`, `orders.notes` (all via `@SanitizedText`), plus `projects.techStack` via `@IsSafeMetadata`. Plain-text

and identity fields (titles, slugs, names, roles, object keys, tokens) are

deliberately not rewritten — their length/type bounds stay as before.

Known limits: the policy neutralizes markup at the write boundary;

renderers must still apply their own contextual escaping (defense in depth,

on top of the CSP in [Security headers](#)). String items

inside arrays (`skills`, `capabilities`) keep their existing type/size bounds

and are out of scope for tag stripping.

Verification

- Unit level: `src/common/sanitization/sanitization.spec.ts` (runs under

`npm run test:esm`) — 27 tests covering tag removal, reassembly payloads,

Unicode preservation, control characters, length bounds, idempotence,

malformed/valid JSON metadata, and the real content DTOs.

- Surface level: the T7 block in `test/app.e2e-spec.ts` asserts that markup is

gone from the actual DB `INSERT` parameters, oversized content returns 400

before any write, and malformed `techStack` JSON returns 400; manual

`curl` evidence lives in the plan notepad,

`.omo/notepads/xolvon-addendum-hardening-docs/evidence/`.

Consolidated security controls

Every control introduced or hardened by the addendum plan

(`.omo/plans/xolvon-addendum-hardening-docs.md`), mapped to its code and to

the addendum \$5 checklist (`.omo/drafts/xolvon-addendum-hardening-docs.md`).

Scope ledger — In scope). All entries verified against the source tree on

2026-09-12.

Control (plan task)	Code	Tests	Addendum \$5 checklist item	Decision
Request integrity / CSRF posture (T3)	<code>src/common/guards/request-integrity.guard.ts</code> — global <code>APP_GUARD</code> (<code>src/app.module.ts:66</code>); <code>POST/PATCH/DELETE</code> only; rejects <code>Sec-Fetch-Site: cross-site</code> and any <code>Origin / Referer</code> outside the allowed set; <code>GET/HEAD/OPTIONS</code> and headerless non-browser requests pass	<code>request-integrity.guard.spec.ts</code> + <code>e2e</code> + curl matrix	"Bearer-only request-integrity/Origin/Fetch-Metadata guard for mutation routes and negative tests" — no cookie-session CSRF tokens	DL-018 (with DL-003)
Security headers (T4)	<code>src/security/security-headers.ts</code> wired at <code>src/main.ts:35–39</code> , before <code>CORS/pipes/filter</code> — see Security headers	<code>src/security/security-headers.spec.ts</code> + curl headers <code>local/ APP_ENV=production</code>	"Helmet security headers with production-only HSTS and explicit CSP/frame/nosniff/referrer policy"	DL-021
CORS whitelist (T5)	<code>src/config/cors.ts</code> (<code>resolveCorsOrigins</code>) + <code>app.enableCors({ origin, credentials: true })</code> at <code>src/main.ts:43–50</code> ; wildcards rejected with credentials; local fallback <code>http://localhost:3001</code>	<code>cors.spec.ts</code> + curl allowed/denied origins	"Explicit CORS origin whitelist per environment"	DL-020
Route-specific throttling (T6)	<code>src/config/throttle.config.ts</code> (5 named groups: default 100, search 30, catalog 30, signed 10, order 10 / min) + <code>@Throttle</code> overrides on controllers; auth login/register 5/min (<code>src/auth/auth.controller.ts:33,42</code>); health skips all groups (<code>src/app.controller.ts:10</code>)	<code>throttle.config.spec.ts</code> + <code>e2e</code> burst tests per group	"Route-specific throttling for public search/catalogs, signed URL, and order creation"	DL-012, DL-016
Trust proxy / client-IP (T6)	<code>src/config/trust-proxy.ts</code> + <code>app.set('trust proxy', ...)</code> (<code>src/main.ts:25–28</code>); <code>unset</code> → <code>false</code> (fail closed against <code>X-Forwarded-For</code> spoofing of throttle buckets), <code>1</code> for one proxy hop, malformed → bootstrap aborts	<code>trust-proxy.spec.ts</code> + live burst with rotating XFF	Throttling correctness prerequisite of the checklist item above	DL-016 (extension)
Input sanitization (T7)	<code>src/common/sanitization/</code> (<code>sanitizeText</code> , <code>parseSafeJson</code> , <code>@SanitizedText</code> , <code>@IsSafeMetadata</code>) wired through the existing global <code>ValidationPipe</code> — see Input sanitization	<code>sanitization.spec.ts</code> (27 tests) + <code>e2e</code> DB read-back	"Input/content sanitization policy for HTML-bearing strings and length limits, with tests and no silent data corruption"	RULES \$95, DL-023 lineage
Password hashing	Argon2id via <code>PasswordService</code> (<code>src/auth/</code>); never exposed in responses	auth unit/e2e	Baseline (pre-addendum), kept	DL-003 context
Refresh-session hygiene	SHA-256 hashed <code>sessions.refresh_token</code> , IP/user-agent capture, expiry purge on refresh, delete on logout (<code>src/auth/auth.service.ts:136–225</code>)	auth unit/e2e	Baseline, kept	DL-003
Input contract enforcement	Global <code>ValidationPipe</code> <code>whitelist</code> + <code>forbidNonWhitelisted</code> + <code>transform</code> (<code>src/main.ts:53–59</code>); DTOs reject unknown properties	every controller spec relies on it	Baseline, kept	—
Safe error surface	<code>AllExceptionsFilter</code> (<code>src/common/filters/all-exceptions.filter.ts</code>); generic 500, no stack/upstream-body/secrets	filter + <code>e2e</code> assertions	Baseline, kept	—
Immutable admin audit	<code>AuditService.record()</code> → <code>admin_audit_logs</code> for <code>verify/activate/cancel/revoke/publish/create/update/delete</code> ; no public endpoint, metadata never leaves the API	audit unit + admin <code>e2e</code>	Baseline, kept (HANDBOOK §7 obligation)	—

Dependency audit status

`npm audit --json` was captured during plan T2 on **2026-09-12**

(evidence: `.omo/notepads/xolvon-addendum-hardening-docs/evidence/t2-audit.json`).

exit code 1 as expected with nonzero findings):

Xo... Backend Documentation xolvon-backend-full-documentation.pdf

Severity	Count
Critical	0
High	4
Moderate	1
Low	2
Total	7

Remediation of the high/moderate residuals and the Dependabot-vs-scanner policy are plan T13 work; no paid scanner has been adopted (DL-023 — OPEN).
No claim of a clean audit is made here.

Known limitations (honest state)

1. **Production D1/R2 live path is BLOCKED, not deployed.** There is no verified staging/production deployment target, secret store, or HTTPS domain in this workspace, and no live evidence is fabricated — see `qa-results.md`. All security verification above is local (unit/e2e/curl against locally booted instances with non-secret config).
2. **CSP and CORS final origins are OPEN DECISIONS.** Staging/production frontend origins and `CSP_CONNECT_SRC` values await owner confirmation (DL-020, DL-021, DL-027); until then the lists default to `'self'` plus the configured `R2_ENDPOINT` origin only.
3. **Monitoring/alerting is interface-only.** `MonitoringPort` (`src/observability/monitoring.port.ts`) has no implementation or provider; vendor and recipients remain OPEN (DL-022).
4. **The request-integrity guard is a browser-CSRF control, not an auth layer.** A `POST/PATCH/DELETE` with no `Origin`, no `Referer`, and no `Sec-Fetch-Site` header (curl, Postman, server-to-service clients) passes the guard by design; such clients still need valid Bearer credentials on every protected route. This is the explicit non-browser bypass policy recorded under DL-018, not an oversight.
5. **Sanitization neutralizes markup at the write boundary only;** renderers must still apply contextual escaping (defense in depth over CSP).